System Security Plan
RAV4 HYBRID

October 10, 2026

SIE 573
College of Engineering
University of Arizona

This document is prepared for
Toyota Motor Manufacturing Kentucky

Team 5

Bhanuprakash Kandimalla

Mukwaya Lwere

Desiree O'Cleireachain

Samuel Yoon



Systems Security Plan

This System Security Plan is a living document. It will be reviewed and updated as the TMMK RAV4 Hybrid Production Line, its threats, or its security controls change, and each revision will be approved by the Authorizing Official and recorded in the table below.

Version	**Date**	**Description**	**Author**
1.0	*10-OCT-2026*	Original release	Team 5

Table of Contents

1. Executive Summary *1*

1.1 Risks and Potential Impact Categorization. **1**

Table 1.1 Risk register summary 1

1.2 Security Controls **2**

1.3 Resilience to Outsider and Insider Attacks **2**

1.4 Recovery **3**

1.5 Stakeholder Responsibilities **3**

Table 1.2. Stakeholder responsibilities for the RAV4 Hybrid production line SSP. 3

1.6 Security Planning Approach **4**

1.7 Objectives of the SSP **4**

2. System Name *4*

Table 2.1. Subsystem inventory. Sources: TMMK (2023, pp. 4–13); Team 5 (2026b). 6

3. System Categorization *6*

3.1 Information Types Categorization **7**

Table 3.1 Information type categorization 7

3.2 Subsystem Categorization **8**

Table 3.2 Subsystem Categorization 8

3.3 Risk Profile Summary **9**

3.4 Impact Level Assignment Methodology **10**

4. System Owner *11*

Table 4.1 System owners by subsystem 11

5. Authorizing Official *11*

6. Organization Structure *12*

Figure 6.1 TMMK RAV4 Production Line Security and Governance Organizational Structure 12

Table 6.1 Roles and Responsibilities of Key Stakeholders 13

7. System Operational Status *13*

Table 7.1 System Operational Status 14

8. System Type *14*

9. General System Description/Purpose *15*

10. Related Laws/Regulations/Policies *15*

Table 10.1 Related Laws, Regulations, Standards and Policies 15

11. System Environment *17*

11.1 Physical Environment **17**

11.2 Technical Environment **18**

Figure 11.2. Logical environment and authorization boundary 19

11.3 Special Security Concerns **20**

12. System Interconnections/Information Sharing ***21***

Figure 12.1. Interconnections and data flows 22

12.1 Interfaces and Information Shared **22**

Table 12.1. Interfaces and information shared 23

12.2 Authorization to Connect or Disconnect **23**

12.3 Interconnection Vulnerabilities **24**

Table 12.2. Vulnerabilities, controls, and authority to disconnect 24

13. Security Controls ***25***

13.1 Security Control Summary Table **25**

13.2 Implementation by control area **26**

13.2.1 Network & Boundary Security (SC family and AC-2 through AC-6(1)) 26

13.2.2 System Integrity & Flaw Management (SI Family and AC-6(2) through AC-18) 28

13.2.3 Identity & Access Management (IA Family and AC-18(1) through AC-22) 29

13.2.4 Contingency, Recovery & Supply Chain (CM, CP, IR, and SR Families) 30

13.2.5 Inherited and Assessment Controls (Remaining Families) 31

13.3 Traceability to Risks **31**

13.4 Recovery walkthrough **33**

14. Summary ***33***

15. References ***35***

16. Appendix A. Acronyms and Terms ***38***

A.1 Acronyms **38**

A.2 Control Family Abbreviations **40**

A.3 Terms and Definitions **41**

A.4 Subsystem Identifiers **41**

1. Executive Summary

Toyota Motor Manufacturing Kentucky (TMMK) RAV4 Hybrid production line operates as a converged information technology/operational technology (IT/OT) system that assembles the latest RAV4 model at an existing TMMK facility. The production line uses an established architecture based on the Purdue model, inherited from the plant's ongoing vehicle manufacturing operations. Enterprise IT is segmented from the supervisory control and data acquisition (SCADA) and distributed control system (DCS) systems that run manufacturing by subnets, virtual local area networks (VLANs), firewalls, proxies, and tunneling. Network traffic between zones is permitted only through demilitarized zones (DMZs) managed by allowlist access control lists (ACLs) (Toyota Motor Manufacturing Kentucky [TMMK], 2023, pp. 4–5). The research and development (R&D) department is physically air-gapped. Its containerized SafetySense 2.0 software is delivered to vehicles through a trusted software delivery server, using encrypted over-the-air installation to the vehicle's trusted platform module (TPM), followed by final quality assurance (QA) hash verification (TMMK, 2023, p. 9).

This System Security Plan (SSP) covers the manufacturing line (the automated guided vehicle [AGV] system, environmental SCADA, and DCS), the R&D and software delivery chain, the hardware supply chain processes that support just-in-time (JIT) production, and the associated network, server, and process controls. The SSP relies on, but does not reassess, enterprise services provided by Toyota Motor North America (TMNA) Corporate IT, such as corporate firewalls, identity management, plant physical security, and mandatory staff training. The scope explicitly excludes supplier-owned systems and vehicles after delivery to customers.

1.1 Risks and Potential Impact Categorization.

In accordance with the course template, this SSP categorizes the system as MODERATE. The team's Risk Management Framework (RMF) assessment, based on Federal Information Processing Standards (FIPS) Publication 199 (National Institute of Standards and Technology [NIST], 2004), rated confidentiality as MODERATE and both integrity and availability as HIGH. Applying the high-water mark principle, the real-world rating would be HIGH (Team 5, 2026b). Altering firmware in customer vehicles is a safety hazard under ISO 26262 (International Organization for Standardization [ISO], 2018), and JIT production processes are highly sensitive to downtime.

Key risks. The risk register identifies five risks (Team 5, 2026b):

ID	Risk	Level
R-01	JIT supply-chain freeze through malware that encrypts shared network dependencies (supplier EDI gateways)	HIGH
R-02	Air-gap tampering and a Stuxnet-style payload on unverified physical media entering the OT DMZ software server	HIGH
R-03	Unauthenticated PLC logic manipulation that overrides safety limits through legacy industrial protocols	HIGH
R-04	CAN bus exploitation through exposed exterior vehicle component interfaces	HIGH
R-05	Public cloud misconfiguration by an administrator that exposes vehicle data	MODERATE

Table 1.1 Risk register summary; source: Team 5 (2026b).

Risk scenarios R-01 through R-03 reside within the defined authorization boundary. A supply-chain freeze (R-01) directly halts Just-In-Time (JIT) production line; due to minimal inventory buffers, any resulting downtime translates immediately to lost manufacturing output. Air gap tampering (R-02) and PLC logic manipulation (R-03) represent severe integrity risks. A compromise in these areas could lead to vehicles being manufactured with unverified safety software or bypass critical floor-worker safety limits, exposing Toyota to statutory recalls under 49 U.S.C. §§ 30118–30120. Conversely, R-04 (post-delivery vehicles) and R-05 (the public cloud) are classified outside the authorization boundary and are documented here to allow their designated owners to formally accept or mitigate them (Team 5, 2026b).

1.2 Security Controls

Controls. The selected controls are based on NIST SP 800-53 Revision 5 (NIST, 2020b). The team workbook identifies 305 controls and enhancements across 18 control families: 287 from the Moderate baseline and 18 additional controls to address OT and boundary-specific requirements. Of these, 173 controls are inherited from Toyota's enterprise services, while 132 are designed specifically for the production line (Team 5, 2026a). The controls are organized into four primary areas: Network & Boundary Security (SC family and AC-2 through AC-6(1)), System Integrity & Flaw Management, Identity & Access Management, and Contingency, Recovery & Supply Chain.

Critical elements in place. The current architecture includes segmented VLANs and allowlist-based DMZs, centrally managed internal firewalls with intrusion detection and prevention at the edge DMZ, an air-gapped R&D enclave with unique credentials, two-factor authentication, and data loss prevention measures. Additional safeguards include encrypted, dedicated transfer media; a version-controlled software registry with an immutable changelog; active-active server configurations; nightly write-once-read-many (WORM) backups with hourly file-level backups; automatic log-off mechanisms; and multiple QA checkpoints (TMMK, 2023, pp. 4–14).

Critical elements planned. The draft RMF assessment proposes OT-aware anomaly detection at the Control and Floor VLAN boundaries, a sign-at-source and verify-at-boot chain of trust anchored in the TPM, continuous monitoring of supplier electronic data interchange (EDI) traffic, and unit-level quarantine procedures when a final QA hash does not match (Team 5, 2026b). The strategic plan relies on four core controls mapped directly to each in-scope risk path. First, AC-4 (Information Flow Enforcement) restricts network traffic exclusively to allowlisted pathways between Purdue model layers. Second, SI-7 (Software and Information Integrity) ensures that SafetySense 2.0 is cryptographically signed at the source and subsequently validated during boot cycles and final Quality Assurance (QA). Third, SR-6 (Supplier Assessments and Reviews) vets suppliers, and supplier data reaches the line read-only. Finally, IR-4 (Incident Handling) dictates the immediate quarantine of any assembly unit exhibiting a QA hash mismatch (Team 5, 2026a, 2026b). Detailed, control-level specifications are documented within the System Security Plan (SSP) control selection workbook (Team 5, 2026a).

1.3 Resilience to Outsider and Insider Attacks

To access a controller, an external threat actor must breach multiple defensive layers. This architectural defense includes corporate firewalls, an Operational Technology (OT) DMZ equipped with deny-by-default allowlists and authenticated proxies, and an intrusion detection system (IDS) at the edge DMZ (SC-7, SC-7(5), SC-7(8), AC-4; TMMK, 2023, p. 13). Because the Research and Development (R&D) enclave is completely air-gapped, its sole ingress point is a strictly monitored, controlled software delivery crossing (TMMK, 2023, p. 9). Internal threats are mitigated through strict role-based access control; operator, maintenance, and engineering roles are explicitly separated to prevent any single account from simultaneously operating, modifying, and administering a given asset (AC-5, AC-6). Furthermore, because software is cryptographically signed at its source and verified both at boot and during final QA, unauthorized code deployment by an insider remains highly detectable (SI-7). Finally,

comprehensive account and firewall event logs are aggregated within the enterprise SIEM, ensuring a permanent, auditable trail for all configuration changes (AC-2(4), AC-4(26)).

1.4 Recovery

Upon detecting an active exploit, the infrastructure prioritizes localized containment prior to initiating system restoration. Affected manufacturing units are immediately quarantined at the Quality Assurance station (IR-4), while the compromised VLAN or subsystem can be logically isolated at the OT DMZ to protect the broader facility from a plant-wide shutdown (SC-7). Operational continuity is maintained across the remaining assembly lines via active-active server clusters and a redundant fiber ring topology (TMMK, 2023, p. 13). System recovery involves restoring controllers and servers from validated, secure baselines (CM-2) alongside immutable, nightly write-once backups engineered to withstand ransomware modification (CP-9; TMMK, 2023, p. 13). Full functional verification is mandatory before production cycles are officially authorized to resume (CP-10), with a sequential, step-by-step breakdown of this recovery lifecycle detailed in Section 13.4.

1.5 Stakeholder Responsibilities

The RAV4 Hybrid production line depends on several teams and roles, each with distinct security responsibilities. Table 1.2 summarizes the stakeholders and their areas of ownership. The SSP documents which controls are inherited from enterprise services, which are shared, and which the line implements itself; the table below maps those responsibilities to the organizations that carry them.

Stakeholder	Security responsibilities
Authorizing Official (TMMK President)	Accepts residual risk and authorizes the line to operate; advised by the TMNA CISO.
TMNA Corporate IT (common control provider)	Provides inherited services: corporate firewalls, IAM, SIEM, PKI, DNS, security training, and enterprise policy.
TMMK Production Engineering Manager	Owns RAV4-PL-OPS, -CTL, -FLR, -DCS, and -ENV: PLC, HMI, and SCADA configuration and OT roles.
TMMK OT Network Security Manager	Owns RAV4-PL-DMZ: firewall rules, segmentation, and OT network monitoring.
R&D Software Engineering Manager	Owns RAV4-PL-SWD: the air-gapped enclave, software registry, signing, and secure transfer.
TMMK Quality Assurance Manager	Owns RAV4-PL-FQA: final hash verification and quarantine of mismatched units.
TMMK Supply Chain Manager	Owns RAV4-PL-HSC and -AGV: supplier assessments, receiving scans, and read-only inventory flows.

Table 1.2. Stakeholder responsibilities for the RAV4 Hybrid production line SSP.

Personnel operational compliance anchors the human element of the system security framework. Line operators and technicians are strictly required to authenticate exclusively with their individual credentials, maintain distinct role separation, prevent concurrent or unmonitored open sessions, and immediately escalate anomalous behavior to the OT Network Security Manager. Modifications to PLC logic or HMI

configurations by operators and maintenance staff are restricted to authorized change management workflows. Furthermore, R&D engineers must utilize encrypted, approved transfer media for all software movement and are prohibited from bypassing cryptographic signing protocols. Within the assembly workflow, Quality Assurance staff must formally hold, rather than release, any vehicle unit failing hash validation checks. Finally, supply chain personnel are mandated to accept only parts and data streams that successfully clear inbound receiving inspections, while external vendors must strictly adhere to the cybersecurity stipulations codified in their service agreements.

1.6 Security Planning Approach

The proposed security framework strictly adheres to the multi-step NIST Risk Management Framework lifecycle (NIST, 2018). During the initial phases, the team categorized the system asset profile in accordance with FIPS 199 and SP 800-60, subsequently selecting the NIST SP 800-53B Moderate baseline enhanced by the SP 800-82r3 Operational Technology (OT) overlay. To maximize fiscal efficiency and reduce redundant engineering overhead, the deployment architecture inherits 173 controls from existing, pre-established Toyota enterprise services. This strategy concentrates new engineering efforts exclusively on the 132 tailored controls, which are prioritized using the risk register to ensure critical, high-exposure vulnerabilities are mitigated first (Team 5, 2026a, 2026b). All planned control milestones are managed within a formalized Plan of Action and Milestones (POA&M / CA-5) and subjected to ongoing continuous monitoring protocols.

1.7 Objectives of the SSP

The SSP documents how each selected security control is implemented in the TMMK RAV4 Hybrid production line so that the authorizing official can make a risk-based decision about operating the system (NIST, 2006, 2018). It has four objectives:

- Describe the system boundary, components, and interconnections accurately enough for assessors to review them.
- Record which controls are inherited from Toyota's enterprise services, which are shared, and which the line must implement itself.
- Show how the selected controls address the five identified risks, and where residual risk remains.
- Give the team and TMMK a single reference for implementation, assessment, and continuous monitoring.

2. System Name

System name: Toyota Motor Manufacturing Kentucky (TMMK) RAV4 Hybrid Production Line. System identifier: RAV4-PL. The system is a manufacturing operations environment that combines R&D and software delivery, the assembly line, and supply chain processes under a common network and security architecture (TMMK, 2023, p. 4).

Table 2.1 lists the subsystems by the Purdue layers used in the RMF assessment, followed by the functional subsystems that run on them. Each subsystem is assigned a unique identifier (Subsystem ID) so that it can be traced through Sections 3, 4, 11, and 12 and the controls workbook. The TMMK RAV4 Hybrid Production Line consists of the following subsystems across the Purdue model layers:

- Level 0 (Floor VLAN): Sensors, actuators, and robotic assembly equipment embedded within the production line.
- Level 1 (Control VLAN): Programmable logic controllers (PLCs) managing robot arms, conveyor belts, welding and painting stations, and environmental controls.

- Level 2 (Ops VLAN): Human-machine interfaces (HMIs) and engineering workstations for local operator control, diagnostics, and maintenance.
- Level 3.5 (OT DMZ): Firewalls, proxy servers, and controlled transfer points separating enterprise IT from OT systems, including the SCADA/historian/AGV application servers, the inventory manager and trusted software delivery server.
- Level 4 (Enterprise IT): Enterprise business systems and interfaces such as MES/ERP, corporate IAM, SIEM, PKI, DNS, and other inherited corporate services. Enterprise IT is external to the production-line OT boundary and interfaces with OT only through approved OT DMZ connections.

This inventory covers both physical devices and virtualized subsystems that support JIT manufacturing, quality control, and secure software distribution. The OT DMZ hosts SCADA/historian/AGV application servers, proxies, and controlled transfer points; AGV fleet devices and environmental SCADA field components remain on their own VLANs/subnets.

Subsystem ID	Subsystem	Description	Network location
RAV4-PL-EIT	Enterprise IT interface (external)	Toyota corporate network and the enterprise services the line inherits: firewalls, IAM, SIEM, PKI, and DNS. The SSP relies on but does not reassess these services.	External — Enterprise IT (Level 4)
RAV4-PL-DMZ	OT DMZ	Firewalls with allowlist ACLs, authenticated proxies, intrusion detection probes that report to the Edge DMZ IPS, SCADA/historian/AGV application servers, and server patch distribution. AGV fleet devices and environmental SCADA field components remain on their own VLANs/subnets.	Level 3.5 — Between Enterprise IT and OT networks
RAV4-PL-OPS	Ops VLAN	Supervisor scheduling and monitoring workstations and HMIs, and the mobile operator and mechanic device. The architecture shows the mobile device on the Maximo Ops VLAN (TMMK, 2023, p.6); this plan places it here because Maximo is outside the authorization boundary.	Level 2 — OT, supervisory layer
RAV4-PL-CTL	Control VLAN	PLCs and control-level traffic between supervisory systems and controllers. PLCs in the same assembly cell communicate over an isolated internal loop network.	Level 1 — OT, control layer
RAV4-PL-FLR	Floor VLAN	Sensors, actuators, and DCS-controlled robotic assembly equipment on the production floor.	Level 0 — OT, field layer
RAV4-PL-AGV	AGV system	Delivers JIT parts and inventory to the floor. Has its own subnet and VLAN and an unpublished, encrypted wireless SSID; applications run active-active where available.	Level 2–3 — Own subnet/VLAN (fleet devices); application servers in OT DMZ
RAV4-PL-ENV	Environmental SCADA	Monitors and controls plant environmental systems (electrical, HVAC, and water/sprinkler). Same	Level 2 — Own

Subsystem ID	Subsystem	Description	Network location
		wireless and redundancy approach as the AGV system.	subnet/VLAN (field components); servers in OT DMZ
RAV4-PL-DCS	DCS	Automates manufacturing and assembly. PLCs on the Control VLAN form an internal loop network; HMIs and supervisor workstations are on separate networks (Ops VLAN).	Levels 0–2 — Control, Floor, and Ops VLANs
RAV4-PL-SWD	Software delivery and R&D	Air-gapped R&D enclave, trusted software delivery server, OT DMZ cluster, software registry, and lightweight TPM with hypervisor for over-the-air installation of SafetySense 2.0.	R&D air gap to OT DMZ (Level 3.5)
RAV4-PL-HSC	Hardware supply chain	Inventory management system, receiving scans, and QA sampling. Inventory data is shared read-only with the AGV and DCS.	Inventory manager in the OT DMZ
RAV4-PL-FQA	Final QA and vehicle database	End-of-line verification of hashes recorded in the vehicle database.	End of line (Level 3)

Table 2.1. Subsystem inventory. Sources: TMMK (2023, pp. 4–13); Team 5 (2026b).

3. System Categorization

- **Confidentiality Potential Impact (MODERATE):** The unauthorized disclosure of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals (NIST, 2004).
    - Within this system, disclosure of proprietary SafetySense 2.0 source code, signing keys, or vehicle build records would seriously harm Toyota's intellectual property and vehicle security (TMMK, 2023, p. 9). Toyota's disclosure of a decade-long cloud misconfiguration that exposed the VINs and location data of over 2 million vehicles shows how damaging vehicle data exposure can be (Powell, 2023).

- **Integrity Potential Impact (MODERATE):** The unauthorized modification or destruction of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals (NIST, 2004).
    - Software integrity is directly linked to physical safety under ISO 26262 (ISO, 2018). Altered firmware flashed into Toyota SafetySense 2.0 would leave the plant inside a customer's vehicle and create a safety hazard on public roads (Team 5, 2026b).

- **Availability Potential Impact (MODERATE):** The disruption of access to or use of information or an information system could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals (NIST, 2004).
    - TMMK's Just-in-Time model has no tolerance for downtime (TMMK, 2023, p. 4). The 2022 Kojima Industries ransomware attack showed that losing supplier data alone can shut down production lines, halting roughly 13,000 vehicles in one day (NPR, 2022).

- **Overall System Impact Level: MODERATE IMPACT.** SC = {(confidentiality, MODERATE), (integrity, MODERATE), (availability, MODERATE)} (NIST, 2004). Categorization is based on potential impact alone, while the risk register rates four risks HIGH because it also weighs likelihood (NIST, 2012; Team 5, 2026b). In a real-world deployment, integrity and availability would likely be rated HIGH; this SSP uses MODERATE per course direction.

3.1 Information Types Categorization

To establish the security baseline for the system, information types were identified and categorized in accordance with NIST SP 800-60 (NIST, 2008a, 2008b) and FIPS 199 (NIST, 2004). Table 3.1 shows the provisional impact levels from SP 800-60, the levels assigned for this system, and the reason for each change.

Table 3.1 Information type categorization

NIST SP 800-60 Information Type	Description / System Context	Provisional C / I / A	Assigned C / I / A	Reason for Change
Manufacturing *(D.22.1 Manufacturing)*	Controls and automated instructions governing physical assembly lines and manufacturing plant operations.	**L / L / L**	**L / M / M**	Tampered control logic can damage equipment or build defects into vehicles, and JIT lines cannot tolerate downtime.
Supply Chain *(C.3.4.2 Inventory Control and C.3.4.3 Logistics Management)*	Inventory records and parts sequencing shared read-only with the AGV and DCS	**L / L / L**	**L / M / M**	Missing or incorrect inventory data immediately stalls JIT part deliveries.
Vehicle Software / Firmware *(C.3.5.1 System Development)*	Code segments, cryptographic signatures, and safety-critical vehicle control logic (e.g., driver-assist packages).	**L / M / L**	**M / M / L**	Contains proprietary safety software; leaks are a top risk per the architecture documentation (TMMK, 2023, p. 9).
Vehicle Build and Verification Records *(organization-defined)*	VIN to Firmware hash records in the vehicle database	**N/A**	**M / M / L**	Database records link each vehicle to its verified software; tampering would mask a faulty or unauthorized installation.
Overall (high-water mark)			**M / M / M**	

Table 3.1 Information Type Categorization. Sources: NIST (2008b); TMMK (2023); Team 5 (2026b)

SP 800-60 allows an organization to define information types it does not list; the Vehicle Build and Verification Records type is defined that way. The security objectives were adjusted for the operational and safety risks specific to vehicle manufacturing. The overall Moderate (M/M/M) categorization rests on the following:

- **Vehicle Software/Firmware** drives the Moderate rating for Confidentiality, because leakage of proprietary safety software is identified as a top risk (TMMK, 2023, p. 9). It also drives the Moderate rating for Integrity, because unauthorized modification directly affects physical safety on public roads under ISO 26262 (ISO, 2018).

- **Manufacturing and supply chain data** drive the Moderate rating for Availability, because the Just-in-Time workflow has no tolerance for downtime (TMMK, 2023, p. 4).

- **Vehicle Build and Verification Records** are rated Moderate for Confidentiality and Integrity because they link each vehicle to its verified software, and tampering would hide a bad install. Availability is Low because a short outage delays record lookup without stopping production.

3.2 Subsystem Categorization

The system is divided into subsystems that follow the plant's segmented, defense-in-depth architecture (TMMK, 2023, pp. 4–5). Following FIPS 199 (NIST, 2004) and SP 800-37 (NIST, 2018), each subsystem was categorized separately, based on the information it processes and the function it performs. Table 3.2 shows the rating for each subsystem and the resulting high-water mark.

Table 3.2 Subsystem Categorization

Subsystem ID	Subsystem	Description / System Context	Confidentiality	Integrity	Availability
RAV4-PL-EIT	Enterprise IT Interface	Corporate services the line inherits: firewalls, IAM, SIEM, PKI and DNS. Outside the authorization boundary.	Inherited; not categorized in this SSP		
RAV4-PL-DMZ	OT DMZ	SCADA servers and databases, control and historian servers, AGV and inventory managers, patch distribution, and read-only DNS and authentication, behind firewalls with allowlist ACLs.	Moderate	Moderate	Moderate
RAV4-PL-OPS	Ops VLAN	Operator HMIs, monitoring, alarms and scheduling.	Low	Moderate	Moderate
RAV4-PL-CTL	Control VLAN	PLCs that execute control logic.	Low	Moderate	Moderate
RAV4-PL-FLR	Floor VLAN	Field devices: robots, sensors, machinery and actuators.	Low	Moderate	Moderate
RAV4-PL-AGV	AGV System	Automated guided vehicles on an unpublished, encrypted SSID that deliver JIT parts to the line.	Low	Moderate	Moderate
RAV4-PL-ENV	Environmental SCADA	Monitoring and control of water/sprinkler and electrical systems.	Low	Low	Moderate
RAV4-PL-DCS	DCS	Automates robotic manufacturing and assembly; HMIs and supervisor workstations are on networks separate from the PLCs.	Low	Moderate	Moderate

Subsystem ID	Subsystem	Description / System Context	Confidentiality	Integrity	Availability
RAV4-PL-SWD	Software Delivery and R&D	Air-gapped R&D enclave, trusted software delivery server, and over-the-air installation of SafetySense 2.0 to the vehicle TPM.	Moderate	Moderate	Low
RAV4-PL-HSC	Hardware Supply Chain	Inventory management system and receiving scans; inventory data is shared read-only with the AGV and DCS.	Low	Moderate	Moderate
RAV4-PL-FQA	Final QA and Vehicle Database	End-of-line verification; firmware hashes are checked and recorded in the vehicle database.	Moderate	Moderate	Low
	Overall (high-water mark)		**Moderate**	**Moderate**	**Moderate**

Table 3.2 Subsystem Categorization. Sources: TMMK (2023, pp. 4–13); Team 5 (2026b).

Taken together, the subsystems give an overall high-water mark of Moderate. The rationale for each objective is:

- **Confidentiality (Moderate):** Driven by Software Delivery and R&D, the Final QA and Vehicle Database, and the OT DMZ. Disclosure of safety-critical source code, signing material, or the authentication data held in the OT DMZ would seriously harm Toyota's intellectual property and vehicle security (TMMK, 2023, p. 9).
- **Integrity (Moderate):** Applies to every subsystem. Unauthorized changes to control logic or firmware could build defects into vehicles, a safety concern under ISO 26262 (ISO, 2018). Environmental SCADA is included because it controls sprinkler and electrical systems.
- **Availability (Moderate):** Driven by the control layers, the AGV System and the Hardware Supply Chain. TMMK runs a Just-in-Time model, so losing any of them halts production (TMMK, 2023, p. 4). Software Delivery and R&D and the Final QA database are rated Low because a short outage delays their work without stopping the line.

3.3 Risk Profile Summary

The risk assessment prepared by Team 5 identified five risks, ranging from the enterprise network down to individual vehicle components (Team 5, 2026b); Table 1.1, Risk Register Summary, in Section 1.1 lists them. Four of the five risks are rated HIGH, yet the system categorization remains MODERATE. Risk ratings combine likelihood and impact (NIST, 2012), whereas FIPS 199 categorization is based on impact alone (NIST, 2004).

The identified risks are categorized into three primary risk groups:

1. **Availability and Supply Chain Halts (High Risk)**
   - **Vector (R-01):** External cybercriminals exploiting dependencies between enterprise networks and third-party suppliers.
   - **Consequence:** Malware encrypts shared infrastructure and cuts off Electronic Data Interchange (EDI) feeds. While the initial compromise occurs outside the authorization boundary, the impact lands directly inside: losing Just-in-Time (JIT) sequencing data instantly halts the assembly line. This mirrors the 2022 Kojima Industries attack, which

disabled 14 Toyota plants for a day and cost roughly 13,000 vehicles in lost production (NPR, 2022).

2. **Integrity and Air-Gap Exploitation (High Risk)**
   Vectors (R-02, R-03, R-04): Adversaries with physical access or malicious insiders compromising multiple levels of the Purdue Model.
   - **Consequence:** Unauthorized code is introduced to the OT DMZ software server via physical media (R-02); the architecture document describes no integrity check at that handoff (TMMK, 2023, pp. 9, 13). Separately, attackers can manipulate control logic over unauthenticated legacy industrial protocols (R-03), risking equipment damage or vehicle defects. Outside the facility boundary (R-04), attackers can physically splice into a vehicle's exterior wiring harness to inject forged CAN bus messages, replicating the RAV4 vulnerabilities seen in CVE-2023-29389 (CVE Details, 2023; Goodin, 2023).
3. **Data Confidentiality Breaches (Moderate Risk)**
   - **Vector (R-05):** Administrative misconfiguration of public-facing cloud environments.
   - **Consequence:** Overlooked cloud storage permissions expose customer vehicle data entries, mirroring a real-world Toyota leak that exposed data for over 2 million drivers (Powell, 2023). This risk originates outside the system boundary and is documented strictly for context.

Risks R-04 and R-05 fall outside the authorization boundary defined in Section 1 and are managed by Toyota's broader enterprise and vehicle cyber programs. Risks R-01 through R-03 drive the control tailoring in Section 13.

3.4 Impact Level Assignment Methodology

The system's security impact level was determined through a structured, four-step process following FIPS 199 (NIST, 2004) and NIST SP 800-60 (NIST, 2008a, 2008b) guidelines:

1. Identify Information Types: The project team identified all information types processed within the environment and mapped them to their provisional impact levels outlined in SP 800-60 (detailed in Section 3.1).
2. Adjust for System Context: Provisional levels were adjusted upward where the plant's Just-in-Time (JIT) manufacturing model or critical vehicle safety considerations magnified the impact of a compromise. Each modification was documented alongside its engineering rationale (see Table 3.1).
3. Categorize Each Subsystem: Every subsystem listed in Section 2 was evaluated and rated for confidentiality, integrity, and availability based on its unique operational functions and data dependencies (detailed in Section 3.2).
4. Apply the High-Water Mark: Following the high-water mark approach (NIST, 2004, 2008a), the highest rating across all subsystems for each security objective determined the final system-wide categorization, resulting in a MODERATE rating for all three objectives.

In a live, real-world industrial deployment, the safety-critical consequences of tampered vehicle firmware under ISO 26262 (ISO, 2018) combined with the assembly line's strict dependence on uninterrupted uptime would likely elevate both integrity and availability to a HIGH impact level. However, per course direction, this SSP maintains a MODERATE classification. This MODERATE-impact designation selects the NIST SP 800-53B Moderate security control baseline (NIST, 2020a), which is tailored to the system's environment in Section 13.

4. System Owner

Table 4.1 assigns a specific system owner, by organizational title, to each subsystem comprising the TMMK RAV4 Hybrid Production Line. In alignment with NIST SP 800-18 and NIST SP 800-37 guidelines, a system owner functions as the primary point of contact (POC) and is responsible for coordinating all system development life cycle (SDLC) activities (NIST, 2006, 2018). Because the source architecture documentation does not explicitly designate individual owners, the specific titles below have been assigned by Team 5 for the purposes of this SSP. All five designated owners report directly to the Authorizing Official (see Figure 6.1).

Table 4.1 System owners by subsystem

Subsystem ID	Subsystem(s)	System owner (title)	Core responsibilities (SDLC and POC)
RAV4-PL-OPS, -CTL, -FLR, -DCS, -ENV	Ops VLAN, Control VLAN, Floor VLAN, DCS, Environmental SCADA	TMMK Production Engineering Manager	Coordinates all logical and physical modifications to industrial network layers; oversees PLC logic and SCADA software updates; functions as the primary operational POC for OT infrastructure.
RAV4-PL-HSC, -AGV	Hardware Supply Chain, AGV System	TMMK Supply Chain Manager	Oversees the core inventory management system and components receiving workflow; manages AGV fleet software deployments; serves as the primary operational POC for Just-in-Time (JIT) parts sequencing and delivery.
RAV4-PL-SWD	Software Delivery and R&D	R&D Software Engineering Manager	Exercises governance over the air-gapped R&D development enclave; manages the planned software-signing process, the manual media transfer process, and maintenance schedules for the software delivery infrastructure.
RAV4-PL-FQA	Final QA and Vehicle Database	TMMK Quality Assurance Manager	Directs end-of-line vehicle cryptographic hash verification processes and maintains the vehicle database; serves as the escalation POC for end-of-line verification failures.
RAV4-PL-DMZ	OT DMZ	TMMK OT Network Security Manager	Manages the OT DMZ servers and internal firewalls, including the allowlist ACL rules. Coordinates and validates software patch distributions entering the production network environment.

Table 4.1 System owners by subsystem. Sources: TMMK (2023, pp. 4–13); Team 5 (2026b).

The Enterprise IT Interface (RAV4-PL-EIT) resides entirely outside the defined authorization boundary and is excluded from system owner assignments in this SSP. This segment is independently operated by Toyota Motor North America (TMNA) Corporate IT acting as the common control provider. Consequently, governance of these external services falls under the jurisdiction of the TMNA Chief Information Security Officer (CISO).

5. Authorizing Official

The Toyota Motor Manufacturing Kentucky (TMMK) President serves as the sole Authorizing Official (AO) for the RAV4 Hybrid Production Line. This centralized designation covers every subsystem listed in Section 2, establishing a single point of accountability for the entire system. Enterprise services

inherited from Toyota Motor North America (TMNA) Corporate IT are authorized separately by that organization; the TMMK President formally relies on those existing authorizations for the inherited security controls.

By definition, the AO is the senior executive with the explicit authority to approve an information system's operation and formally accept its residual risk (NIST, 2006, 2018). The TMMK President assumes this role because they possess the site-wide authority and operational budget necessary to accept risks directly impacting physical vehicle production volumes, plant cyber resilience, and driver safety. To ensure informed risk management decisions, the TMNA Chief Information Security Officer (CISO) and the local Information System Security Officer (ISSO) serve as direct advisors to the AO (see Figure 6.1).

During the RMF Authorize step (NIST, 2018) and in compliance with control CA-6 (NIST, 2020b), the AO evaluates the formal authorization package, which includes this System Security Plan (SSP), the Security Assessment Report (SAR), and the Plan of Action and Milestones (POA&M). Upon approval, the AO signs the Authorization to Operate (ATO) and officially accepts all residual operational risks. Furthermore, under control CA-5, the AO maintains responsibility for reviewing and approving the POA&M, which tracks the remediation of outstanding system vulnerabilities (NIST, 2020b).

6. Organization Structure

Security responsibility for the line is divided into three groups. The first oversees and authorizes the system: the TMMK President as Authorizing Official, the ISSO, and an independent assessor. The second, TMNA Corporate IT, provides the enterprise services the line inherits. The third operates the line: five plant system owners and the staff who report to them. Suppliers sit outside the organization and have no access to the OT networks. Figure 6.1 shows how these groups connect, and Table 6.1 lists each role's responsibilities.

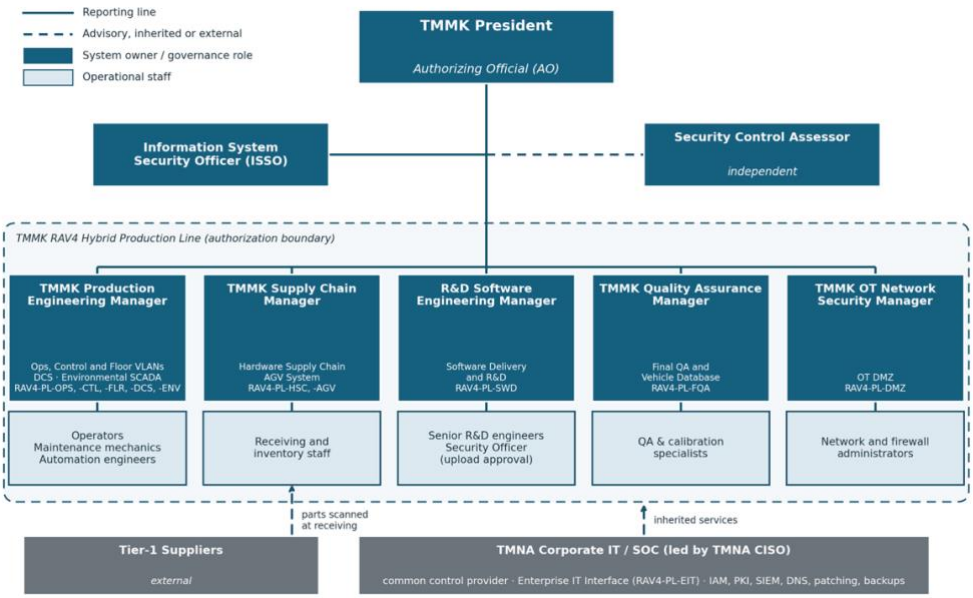


Figure 6.1 TMMK RAV4 Production Line Security and Governance Organizational Structure. Source: Team 5, based on TMMK (2023) and Team 5 (2026b).

The TMMK President acts as the sole Authorizing Official (AO), as detailed in Section 5. Directly supporting the AO, the Information System Security Officer (ISSO) operates independently of day-to-day manufacturing operations to oversee continuous Risk Management Framework (RMF) compliance and ongoing system monitoring (NIST, 2018). Furthermore, a separate, independent Security Control Assessor assesses the security controls, consistent with control CA-2(1) (NIST, 2020b).

The overall governance structure clearly separates inherited corporate services from localized plant operational responsibilities:

- **Inherited Corporate Services:** Centralized functions, including Identity and Access Management (IAM), Public Key Infrastructure (PKI), Security Information and Event Management (SIEM) log aggregation, and global Security Operations Center (SOC) monitoring, are provided directly by TMNA Corporate IT acting as the common control provider (TMMK, 2023, p. 13; Team 5, 2026a, 2026b). The air-gapped R&D enclave stands as the exception; it maintains no network connectivity to corporate services, relying instead on localized credentials and dedicated two-factor authentication (TMMK, 2023, p. 9).
- **Plant System Owners:** Operational oversight is distributed among five distinct system owners who manage the subsystems listed in Table 4.1. To reduce the insider threat vectors identified in Section 3.3, physical assembly and network operations (managed by Production Engineering, Supply Chain, and OT Network Security) are kept separate from software integrity functions (managed by R&D Software Engineering and Quality Assurance). This organizational division supports the separation of duties required by control AC-5 (NIST, 2020b). Additionally, this layout supports the planned dual-authorization pipeline, requiring a Senior R&D Engineer to execute each software upload and the Security Officer to formally approve it prior to deployment (Team 5, 2026b).

Table 6.1 Roles and Responsibilities of Key Stakeholders

Role	Responsibilities
Authorizing Official *(TMMK President)*	Grants formal approval to operate the system; assumes final accountability for residual operational risks; reviews and signs off on the Plan of Action and Milestones (POA&M).
ISSO	Governs comprehensive RMF compliance lifecycle and continuous monitoring strategies; maintains the System Security Plan (SSP).
Security Control Assessor	Conducts unbiased, independent evaluations of implemented security controls and delivers the Security Assessment Report (SAR) to the AO.
System Owners (five)	Serve as the primary operational points of contact for assigned subsystems; manage localized SDLC activities; ensure correct implementation of assigned security controls.
Operational Staff	Maintain and operate assembly line components within assigned permissions; strictly adhere to established access control policies and formal change management procedures.
TMNA Corporate IT / SOC	Delivers inherited enterprise-level security controls, identity infrastructure, and continuous cross-boundary security event monitoring.
Tier-1 Suppliers	Deliver physical components, which are scanned into the inventory system at receiving; have no direct access to plant operational technology networks.

Table 6.1 Roles and Responsibilities of Key Stakeholders.

7. System Operational Status

The authorized system is currently running in the production/operational environment. (NIST, 2006)

Subsystem	Description	Operational Status
Enterprise IT interface	Toyota corporate network and the enterprise services the line inherits: firewalls, IAM, SIEM, PKI, and DNS.	Operational
OT DMZ	Firewalls with allowlist ACLs, authenticated proxies, intrusion detection probes that report to the Edge DMZ IPS, and server patch distribution.	Operational
Ops VLAN	Supervisor scheduling and monitoring workstations and HMIs.	Operational
Control VLAN	Control-level traffic between supervisory systems and controllers.	Operational
Floor VLAN	Sensors, actuators, and DCS-controlled robotic assembly equipment.	Operational
AGV system	Delivers JIT parts and inventory to the floor. Has its own subnet and VLAN and an unpublished, encrypted wireless SSID; applications run active-active where available.	Operational
Environmental SCADA	Monitors and controls plant environmental systems. Same wireless and redundancy approach as the AGV system.	Operational
DCS	Automates manufacturing and assembly. HMIs and supervisor workstations are on networks separate from the PLCs, and PLCs form an internal loop network.	Operational
Software delivery and R&D	Air-gapped R&D enclave, trusted software delivery server, OT DMZ cluster, software registry, and lightweight TPM with hypervisor for over-the-air installation of SafetySense 2.0.	Operational
Hardware supply chain	Inventory management system, receiving scans, and QA sampling. Inventory data is shared read-only with the AGV and DCS.	Operational
Final QA and vehicle database	End-of-line verification of hashes recorded in the vehicle database.	Operational

Table 7.1 System Operational Status

8. System Type

The system is a Manufacturing Operational Technology (OT) / Industrial Control System (ICS) that supports Toyota's Hybrid RAV4 manufacturing operations. The system is used to monitor, control, and automate manufacturing processes through industrial control and supervisory technologies, including PLCs/RTUs, HMIs, SCADA systems, engineering workstations, industrial networks, robots, sensors, actuators, AGVs, and related manufacturing equipment. The system also supports authorized supply-chain services, Just-in-Time (JIT) material operations, and third-party hardware, software, and vendor maintenance activities necessary to support manufacturing operations. Its primary role is to provide the operational control, automation, monitoring, and supporting services required for safe, reliable, and continuous vehicle production.

9. General System Description/Purpose

The TMMK manufacturing Operational Technology (OT) system supports the production of Hybrid RAV4 vehicles by providing the monitoring, control, automation, and data-collection capabilities required for manufacturing operations. The system uses a segmented Purdue Model-based architecture that separates Enterprise IT, OT supervisory systems, industrial control systems, and physical manufacturing equipment into distinct network environments. The primary architecture consists of Enterprise IT, an OT Demilitarized Zone (DMZ), an Operations (Ops) VLAN, a Control VLAN, and a Floor VLAN.

The Enterprise IT environment provides shared corporate services that support manufacturing operations, including enterprise applications, authentication, DNS, file services, backups, patching, and firewall management. A separate Research and Development (R&D) environment supports engineering and software development activities. The OT DMZ serves as an intermediary environment between the Enterprise IT and industrial networks and contains manufacturing-related supervisory and support services, including SCADA servers and databases, control and historian servers, Automated Guided Vehicle (AGV) and inventory management systems, patching services, read-only DNS and authentication services, and security monitoring and inspection tools.

Within the Industrial environment, the Ops VLAN provides supervisory functions such as operator interfaces, process monitoring, alarms, and production scheduling. The Control VLAN contains Programmable Logic Controllers (PLCs), Remote Terminal Units (RTUs), and other industrial controllers that execute control logic. The Floor VLAN contains field-level manufacturing equipment and devices, including industrial robots, sensors, machinery, AGVs, environmental monitoring devices, actuators, and other equipment that directly interacts with the physical manufacturing process.

The system's primary purpose is to provide reliable and controlled operation of manufacturing processes while enabling authorized personnel and applications to monitor production activities, manage equipment, execute control functions, collect manufacturing data, and support maintenance and troubleshooting. The segmented architecture and controlled interfaces between the various environments support the safe, reliable, and continuous operation of the manufacturing system.

10. Related Laws/Regulations/Policies

The TMMK RAV4 Hybrid Production Line is subject to federal vehicle safety and trade-secret law, federal cybersecurity guidance, and the industry standards and corporate policies that Toyota applies across its plants. The system itself holds no customer personal data; therefore, consumer privacy laws apply strictly to Toyota’s enterprise-level environments and fall outside this specific authorization boundary. The Table 10.1 lists each applicable authority, its legal type, the primary security objectives it drives, its direct system requirements, and the related NIST SP 800-53 Rev. 5 controls (NIST, 2020b).

Table 10.1 Related Laws, Regulations, Standards and Policies

Authority	Type	Objective	What it requires of this system	Related controls
National Traffic and Motor Vehicle Safety Act (49 U.S.C. §§ 30118–30120) and Federal Motor Vehicle	Federal law	Integrity	Requires a manufacturer to notify NHTSA and remedy any safety-related defect, including defective software, and requires each vehicle to meet the federal safety standards. The firmware	SI-7, CM-3, SI-2

Authority	Type	Objective	What it requires of this system	Related controls
Safety Standards (49 C.F.R. Part 571)			deployed to each vehicle must remain the exact version that was validated.	
Defend Trade Secrets Act (18 U.S.C. § 1836) and Kentucky Uniform Trade Secrets Act (KRS 365.880–365.900) (Kentucky Uniform Trade Secrets Act, 2025)	Federal and state law	Confidentiality	Provides that trade-secret protection depends on the owner taking reasonable measures to maintain information secrecy. SafetySense 2.0 source code must be strictly access-controlled to prevent leakage.	AC-3, AC-6, SC-28
Cyber Incident Reporting for Critical Infrastructure Act (6 U.S.C. § 681 et seq.)	Federal law; final rule pending as of October 2026 (Cybersecurity and Infrastructure Security Agency [CISA], n.d.)	Availability	Requires covered critical-infrastructure entities to report significant cyber incidents directly to CISA within 72 hours and ransom payments within 24 hours once the final rule takes effect.	IR-4, IR-6
NHTSA (*Cybersecurity Best Practices for the Safety of Modern Vehicles* (2022) (National Highway Traffic Safety Administration [NHTSA], 2022)	Federal guidance (non-binding)	Integrity	Recommends implementing layered protection strategies over vehicle software environments and establishing secure update processes.	SI-7, CM-7, SA-11
ISO 26262, Road vehicles — Functional safety (ISO, 2018)	Industry standard	Integrity	Calls for safety-related vehicle software to be developed, managed, and verified under a strictly controlled process.	SI-7, SA-11, CM-3
ISO/SAE 21434, Road vehicles — Cybersecurity engineering (ISO & SAE International, 2021)	Industry standard	Integrity, Confidentiality	Calls for comprehensive cybersecurity risk management across the entire vehicle lifecycle, which explicitly includes the production phase.	SI-7, SR-3, CA-7
IEC 62443-3-2 and NIST SP 800-82 Rev. 3 (NIST, 2023) (International Electrotechnical Commission [IEC], 2020)	Standard and guidance	Availability, Integrity	Recommends that industrial control networks be segmented into distinct zones with tightly regulated, controlled connections between them.	AC-4, SC-7, SI-4
NIST SP 800-161 Rev. 1 (NIST, 2022) and IATF 16949 (International Automotive Task Force [IATF], 2016)	Guidance and industry standard	Integrity, Availability	Calls for supplier risk assessments and formal validation procedures for all incoming physical and logical components.	SR-3, SR-5, SR-6, SR-11
FIPS 199, NIST SP 800-37 and SP 800-53	Federal standards, adopted voluntarily	All three	Serves as the foundational framework for the categorization, risk management process, and	CA-6, CP-2

Authority	Type	Objective	What it requires of this system	Related controls
			security control baseline used throughout this SSP. Federal law does not mandate a private manufacturer to implement them.	
Other standards named in the architecture document: ASPICE, ISO 9001, ISO/IEC 27001, ISO/IEC 27034, ISO 14001, ISO 45001	Industry standards	Integrity, Availability	Cover quality management, information security management, secure software development lifecycles, and environmental and worker-safety controls across the manufacturing facility (TMMK, 2023, p. 3).	SA-11, CP-2, SI-17
Toyota corporate information security policy	Organizational policy	All three	Serves as the basis for the inherited enterprise controls, the physical R&D air-gap architecture, and formal removable media transfer procedures (TMMK, 2023, pp. 9, 13).	AC-5, CA-3

Table 10.1 Related laws, regulations, standards and policies. Sources: as cited in the table; TMMK (2023).

11. System Environment

The RAV4 Hybrid line is new, but the plant around it is not. TMMK already builds vehicles at this site, so the line goes into an existing campus, network, and security program and adds its own equipment and software delivery path to them (TMMK, 2023, pp. 2, 4). This section describes the physical environment, the technical environment, and the conditions that raise special security concerns.

11.1 Physical Environment

Physical security is layered from the fence line inward (Figure 11.1). An eight-foot fence topped with barbed wire surrounds the campus. Vehicles enter only through automated gates, usually with a guard checkpoint, and pedestrian gates are badge-only and watched by cameras around the clock. Inside, color-coded RFID badges open the buildings, every entrance has electromagnetic locks, cameras, and motion sensors, and only trained staff in distinctive black clothing work at critical build points (TMMK, 2023, pp. 11–13). Plant Security and Facilities runs these controls and the line inherits them; all 18 Physical and Environmental Protection (PE) controls are designated Common and Inherited (Team 5, 2026a).

Two spaces get more. The R&D enclave is air-gapped, allows no wireless, and requires unique credentials and two-factor authentication (TMMK, 2023, pp. 5, 9). Software leaves it only on dedicated, encrypted storage devices that are wiped and verified before they come back (TMMK, 2023, p. 13), and the RMF assessment adds an upload terminal under camera and endpoint monitoring for each transfer (Team 5, 2026b). The architecture description does not say where the OT DMZ servers sit, so this plan assumes a badge-restricted equipment room.

Figure 11.1. Physical security layers around the RAV4 Hybrid line

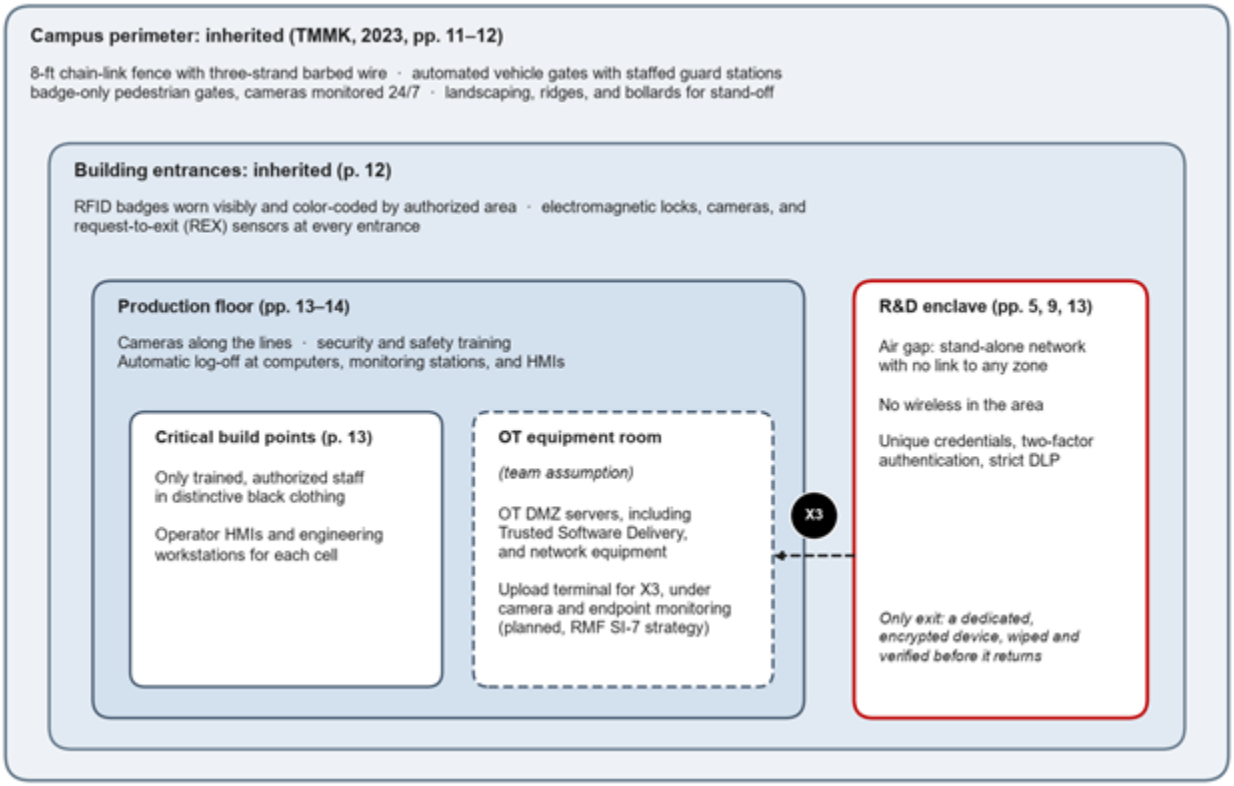


Figure 11.1. Physical security layers. Each layer has to be passed to reach the next, and the R&D enclave's only exit is the manual transfer at X3. Sources: TMMK (2023, pp. 5, 9, 11–14); Team 5 (2026b). The OT equipment room is a team assumption.

11.2 Technical Environment

The plant network follows the Purdue model (Figure 11.2). From the outside in, the Internet meets an edge firewall and the Edge DMZ. An internal firewall separates the Edge DMZ from Enterprise IT, which provides ERP, authentication, DNS, patching, backup, and firewall management. Two more internal firewalls separate Enterprise IT from the OT DMZ (crossing X1) and the OT DMZ from the industrial network (X2), and each passes only the traffic its allowlist defines (TMMK, 2023, pp. 4–6, 13). The OT DMZ holds two matching server groups, each with SCADA servers and databases, control and historian servers, and the AGV and inventory managers, running active-active where the application supports it. It also holds the Trusted Software Delivery server, patch distribution, read-only DNS and authentication servers, and a network inspection probe (TMMK, 2023, pp. 6, 13).

Figure 11.2. Logical environment and authorization boundary

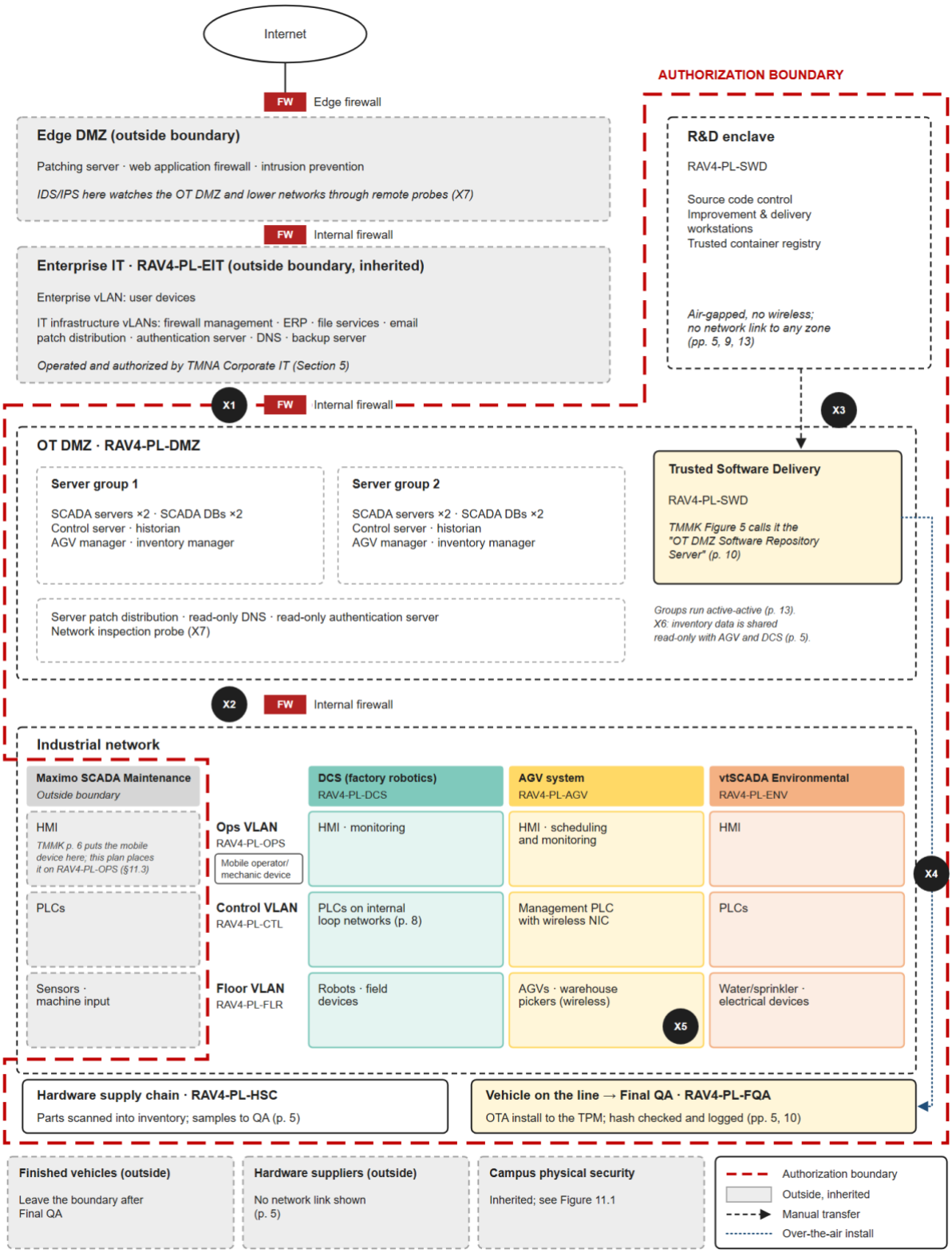


Figure 11.2. Logical environment and authorization boundary. The industrial network repeats one pattern four times, Ops over Control over Floor, and every path into it passes through the OT DMZ. Redrawn from TMMK (2023, Figure 1, p. 6); the boundary, subsystem IDs, and crossing labels are the team's (Team 5, 2026b).

Below the OT DMZ sit three in-scope subsystems: the DCS for factory robotics (RAV4-PL-DCS), the AGV system (RAV4-PL-AGV), and vtSCADA Environmental Control (RAV4-PL-ENV). A fourth stack, Maximo SCADA Maintenance Control, is an enterprise service outside the authorization boundary. Each is split into the same three layers: an Ops VLAN for HMIs and monitoring, a Control VLAN for PLCs, and a Floor VLAN for sensors, robots, and other field devices (TMMK, 2023, p. 6). The line is built to keep running through a failure. Wired control systems uplink over a redundant fiber ring, servers fail over active-active, and backups are written nightly to write-once storage that protects them from ransomware (TMMK, 2023, p. 13). Enterprise IT, the Edge DMZ, campus security, finished vehicles, and hardware suppliers lie outside the authorization boundary and are inherited or excluded rather than assessed here.

11.3 Special Security Concerns

SP 800-18 asks a plan to name the environmental and technical factors that raise special security concerns (NIST, 2006, p. 22). Five apply to this line.

Physical access. On a plant floor, physical access is logical access. TMMK already logs computers, monitoring stations, and HMIs off automatically where the function exists, to stop "unauthorized individuals physically walking up to a station and making changes" (TMMK, 2023, p. 14). Operator HMIs that must stay live through an alarm are the exception (Section 13.2.2), and for those the badge-controlled area around them is the main protection. Two of the five risks start with someone physically inside the plant: an insider changing PLC logic (R-03) and a payload carried across the air gap (R-02) (Team 5, 2026b).

Mobile devices. The line's one handheld device is the mobile operator and mechanic device. The architecture document shows it on the Maximo Ops VLAN (TMMK, 2023, p. 6), but because Maximo is outside the authorization boundary, this plan places the device on the in-scope Ops VLAN (RAV4-PL-OPS), so that it falls under the line's controls. Mobile devices on the OT networks are therefore limited to organization-controlled, encrypted devices (Section 13.2.3). The only other portable devices are the encrypted storage devices used for the R&D transfer.

Wireless. Wireless serves the AGVs and the automated pickers in the warehouse, the environmental SCADA system, and the over-the-air install to each vehicle (TMMK, 2023, pp. 5–7). The AGV and environmental networks use unpublished, encrypted SSIDs on networks of their own, preprogrammed onto designated devices so that employee phones cannot interfere (TMMK, 2023, pp. 4, 6–7). SP 800-82 treats a unique SSID and MAC address filtering as minimum settings and relies on encryption and separate segments for protection (NIST, 2023, p. 121). The bigger concern is availability. Wireless is more exposed to jamming than wire (NIST, 2023, p. 122), and on a Just-in-Time line a jammed AGV network stops parts delivery as surely as ransomware does. No wireless is allowed in R&D (TMMK, 2023, p. 9).

Networks. The industrial protocols below the OT DMZ, such as Modbus and PROFINET, carry no authentication, so any host that reaches a Control VLAN can send a PLC a command it will accept (Team 5, 2026b). Segmentation is the main protection there, and the RMF assessment treats each Purdue transition, down to the Control and Floor VLANs, as a separate barrier (Team 5, 2026b). The fiber ring keeps the line connected, but it carries a malicious command as reliably as a legitimate one.

Who has access to what. Table 11.1 shows what each role can do in each part of the line. TMMK describes the zones but not who may enter them, so these assignments are this plan's. They follow the owners in Section 4 and the operator, maintenance, and engineering roles in Section 13.2.1. Two systems also hold standing access: the inventory manager feeds the AGV and DCS read-only, and the inspection probe watches every OT zone for intrusion detection at the Edge DMZ (TMMK, 2023, pp. 5, 13).

Table 11.1. Access by role and zone

Role	OT DMZ servers	Ops VLAN (HMIs)	Control VLAN (PLCs)	Floor VLAN (field devices)	R&D enclave	Final QA
Operators	—	Operate	—	—	—	—
Maintenance staff	—	Operate	View	Maintain	—	—
OT engineers	View	Configure	Configure	Configure	—	—
OT Network Security	Configure	Monitor	Monitor	Monitor	—	—
R&D engineers	Upload	—	—	—	Develop	—
Security Officer and ISSO	Approve uploads	Monitor	Monitor	Monitor	—	—
Quality Assurance	—	—	—	—	—	Operate
TMNA Corporate IT and SOC	Push through X1	—	—	—	—	—
Equipment vendors (assumed)	Session	—	Support only	—	—	—
Suppliers	—	—	—	—	—	—

Table 11.1. Access by role and zone. ***Operate:*** *run the process from an HMI or station.* ***View:*** *read status or diagnostics.* ***Maintain:*** *physical work on field equipment.* ***Configure:*** *change logic, settings, or rules, with each change logged.* ***Monitor:*** *watch traffic, logs, and alerts.* ***Upload, Approve uploads, Develop:*** *the R&D transfer steps in Section 6.* ***Push through X1:*** *patches, firewall rules, and DNS and authentication data.* ***Session, Support only:*** *an individually approved vendor session through the managed entry point (team assumption). Assignments are this plan's; titles follow Sections 4 and 6.*

12. System Interconnections/Information Sharing

SP 800-18 defines an interconnection as the direct connection of two or more systems to share information, and warns that an unprotected one can compromise every system on it (NIST, 2006, p. 23). By that definition the line has one documented interconnection with another organization's system: Enterprise IT, run by TMNA Corporate IT, at crossing X1. The other crossings are interfaces inside the boundary, or in X7's case a monitoring feed out to the Edge DMZ, and they matter as much, because they are where the line's risks travel. Crossings X1 to X7 come from the RMF assessment; A1 and A2, links to suppliers and equipment vendors, are connections the team assumes but the architecture description does not show (Team 5, 2026b). Figure 12.1 shows each one and its direction.

Figure 12.1. Interconnections and data flows

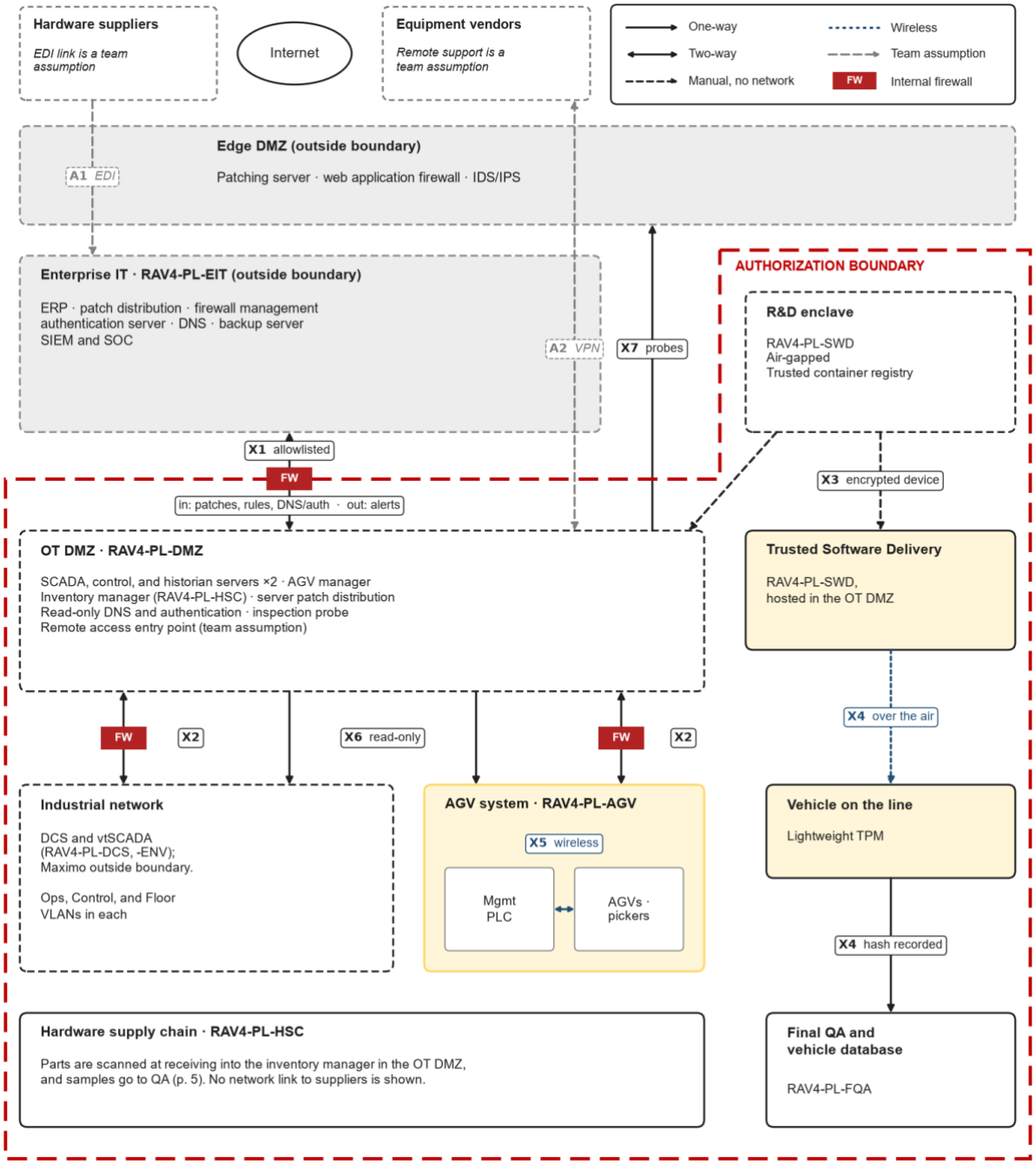


Figure 12.1. Interconnections and data flows. Most flows run one way; the two-way crossings are X1, X2, X5, and the assumed vendor path A2. Grey dashed flows are team assumptions. Sources: TMMK (2023, pp. 4–13); Team 5 (2026b).

12.1 Interfaces and Information Shared

Table 12.1 lists what crosses each connection, in which direction, and what protects it today. Most flows run one way by design. Software leaves R&D on a device that comes back wiped, inventory data reaches the AGV and DCS read-only, and monitoring data flows out to the Edge DMZ (TMMK, 2023, pp. 5, 13). The two-way crossings are X1, X2, X5, and the assumed vendor path A2. X1 and X2 are the ones the risk

register worries about most: X1 is the path R-01 ransomware would take toward the line, and X2 carries the commands R-03 is about (Team 5, 2026b). Supplier data (A1) and vendor sessions (A2) also pass through X1 (Sections 13.2.1 and 13.2.2), but each has its own row because it involves another organization and needs its own agreement.

Table 12.1. Interfaces and information shared

ID	Connection and direction	Information shared	How it crosses today
X1	Enterprise IT ↔ OT DMZ (two-way)	Inbound: patches, firewall rule changes, and DNS and authentication data for the read-only servers (implied by TMMK, 2023, pp. 6, 13). Outbound, one way: alerts and logs to the enterprise SIEM (team assumption)	Internal firewall with an allowlist; proxies and tunneling where data must cross (TMMK, 2023, pp. 4, 6, 13)
X2	OT DMZ ↔ the Ops, Control, and Floor VLANs of DCS, AGV, and ENV (two-way)	Down: supervisory commands, setpoints, schedules, AGV tasks. Up: process values, alarms, historian data	Internal firewall with an allowlist; HMIs and supervisor workstations on separate networks from PLCs (TMMK, 2023, pp. 6, 8)
X3	R&D enclave → Trusted Software Delivery and the OT DMZ cluster (one-way, by hand)	Trusted software containers, including SafetySense 2.0	No network link; dedicated encrypted devices, wiped and verified before they return to R&D (TMMK, 2023, pp. 5, 13)
X4	Trusted Software Delivery → vehicle TPM → Final QA (one-way)	Software package to the vehicle; installed hash to the vehicle database	Encrypted wireless VLAN; TPM verification at each boot; hash check at Final QA (TMMK, 2023, pp. 5, 10)
X5	AGV management PLC ↔ AGVs and warehouse pickers (two-way, wireless)	Delivery tasks out; device status back	Unpublished, encrypted SSID on its own subnet and VLAN (TMMK, 2023, pp. 4, 6–7)
X6	Inventory manager → AGV and DCS (one-way)	Inventory and parts-sequencing data	Read-only sharing (TMMK, 2023, p. 5)
X7	Inspection probes in the OT DMZ and lower networks → Edge DMZ IDS/IPS (one-way, outbound)	Traffic observations and alerts	Remote network probes (TMMK, 2023, p. 13)
A1	Suppliers → Enterprise IT → inventory manager (one-way, team assumption)	EDI orders, shipping notices, and sequencing data	Read-only, monitored supplier flows planned in the RMF assessment (Team 5, 2026b); not shown in TMMK
A2	Equipment vendors ↔ OT DMZ entry point (two-way per session, team assumption)	Remote diagnostics; changes only during documented support	Corporate VPN ending at one managed entry point (Section 13.2.2)

Table 12.1. Interfaces and information shared. X1–X7 from Team 5 (2026b); A1 and A2 are team assumptions.

12.2 Authorization to Connect or Disconnect

No crossing is added or changed without approval. SP 800-18 calls for an interconnection security agreement (ISA) or memorandum of understanding (MOU) between systems run by different organizations (NIST, 2006, p. 23). For X1, that means an ISA under an MOU between TMMK and TMNA Corporate IT, approved by the authorizing official (AO). TMNA authorizes Enterprise IT itself, and the AO relies on that authorization (Section 5). This is CA-3 in Section 13. Connections inside the boundary go through change control instead. The manager who owns the subsystem and the OT Network

Security Manager, who owns the OT DMZ and its allowlists, approve each one (CA-9; Section 4). A1 and A2 would need agreements like X1's, with supplier and vendor contracts carrying the security terms.

Disconnecting is faster by design. SP 800-47 allows an organization that detects an attack to cut an exchange at once, after consulting technical staff and senior management, and to restore it by returning to the planning or establishing phase (NIST, 2021, pp. 29–30). Table 12.2 names who can cut each crossing. The plan gives the cheap cuts, such as a vendor session or a single Control VLAN segment, to OT staff on the spot, and leaves the cuts that stop production to the manager who answers for it. Cutting X1 costs the line its patches and enterprise monitoring; cutting X5 costs it its parts.

12.3 Interconnection Vulnerabilities

Table 12.2 names the weakness each crossing creates, the risk it feeds, the Section 13 controls that answer it, and who can disconnect it.

Table 12.2. Vulnerabilities, controls, and authority to disconnect

ID	Vulnerability (risk)	Section 13 controls	Who can disconnect
X1	A compromised enterprise host or account uses an allowed flow, or uses central firewall management to widen the allowlist itself; patches arrive through X1 by design, so a malicious or faulty one would too (R-01)	AC-4, AC-4(7), AC-4(9), SC-7(5), SI-2, CM-4	OT Network Security Manager at the internal firewall; TMNA SOC from the enterprise side
X2	Industrial protocols carry no authentication, so any host on a Control VLAN can write to a PLC (R-03)	AC-4(2), AC-6(10), SI-4(2), IR-4	On-site engineers isolate one Control VLAN segment without a plant-wide halt
X3	Nothing checks the package at the handoff, and one bad transfer can reach both the vehicle and the OT DMZ servers (R-02)	SI-7, SI-3, AC-5, CM-5	R&D Software Engineering Manager; the Security Officer can refuse an upload
X4	A tampered package is caught only after installation, at Final QA (R-02, R-04)	SI-7(1), SI-7(7), IR-4, SC-8(1)	Automatic on a Final QA hash mismatch: the unit is quarantined and installs from that build freeze (IR-4); the QA Manager is the escalation contact
X5	Jamming or a rogue access point stops the AGVs (availability; not in the register)	AC-18, AC-18(1), SC-5	OT Network Security Manager, on the Supply Chain Manager's decision
X6	Read-only blocks writes back, but bad inventory data still drives deliveries (R-01)	AC-4(7), SI-10, CP-9	OT Network Security Manager at the OT DMZ
X7	A compromised probe could bridge the zones it watches, and Edge DMZ sensors do not read industrial commands (R-03)	SI-4, SI-4(2), AC-4(21)	OT Network Security Manager
A1	Ransomware on a supplier link spreads inward, or losing the link starves Just-in-Time sequencing (R-01)	SC-7(4), AC-4(7), SR-6, CP-2	TMNA SOC or OT Network Security Manager (IR-4)
A2	Stolen vendor credentials give a remote path to PLC programming (R-03)	AC-17(3), AC-17(9), AC-17(10), AC-20	OT staff at the entry point (AC-17(9))

Table 12.2. Vulnerabilities, controls, and authority to disconnect. Risks from Team 5 (2026b); controls from Team 5 (2026a); titles follow Section 4.

Read down the table and one pattern repeats. The architecture is good at deciding where traffic can go: allowlists at every boundary, an air gap, read-only feeds, and wireless reserved for its own devices. It is weaker at checking whether what arrives is genuine. Commands at X2 and software at X3 are trusted because of the path they took, and nothing on that path verifies them; software at X4 is checked, but only

after it is installed. Section 13 divides the work along that line. Network & Boundary Security (13.2.1) keeps the paths narrow, and System Integrity & Flaw Management (13.2.2) adds checks on what crosses them: signed software, baselines for PLC logic, and monitoring that reads industrial commands.

13. Security Controls

This section documents the security controls selected to protect the TMMK RAV4 Hybrid Production Line. The team started from the NIST SP 800-53 Rev.5 Moderate baseline (NIST, 2020a), applied the SP 800-82 Rev.3 OT overlay (NIST, 2023), and tailored the result to the line's architecture, for a total of 305 controls. Section 13.1 introduces the controls workbook that serves as the summary table, Section 13.2 describes how the controls are implemented in each control area, Section 13.3 traces the controls to the five risks, and Section 13.4 walks through recovery from an attack.

13.1 Security Control Summary Table

The SSP Controls Selection Workbook **(SSP_Controls_Selection.xlsx)** is submitted separately as the authoritative Security Control Summary Table for this System Security Plan. The workbook contains every selected NIST SP 800-53 Revision 5 control and control enhancement, grouped by control family and traceable to the detailed implementation discussions in Section 13.

The control-selection process begins with the NIST SP 800-53 Rev. 5 Moderate baseline and tailors that baseline for the Toyota Motor Manufacturing Kentucky production-line operational technology environment using NIST SP 800-82 Rev. 3 guidance. The workbook identifies each selected control by control family, control identifier, control name or concise description, implementation information, control type, and Tailored or Inherited designation. The Privacy, Low, and High baseline columns are excluded from the final summary table because they are not required for this Moderate-system submission.

The selected control set includes 305 controls and enhancements across 18 control families. Of these selections, 287 are from the NIST SP 800-53 Rev. 5 Moderate baseline. The remaining 18 controls or enhancements are tailored additions needed to address OT-specific security, network-boundary protection, controlled information flows, production availability, and the segmented Purdue-model architecture. The workbook clearly identifies each addition outside the Moderate baseline; Section 13.2 explains why each is retained.

The additional selections include 15 AC-4 Information Flow Enforcement enhancements. These controls enforce authorized communications across the Enterprise IT network, OT demilitarized zone, Operations VLAN, Control VLAN, and Floor VLAN. The implementation uses OT-DMZ firewalls, allowlist access-control lists, VLAN and subnet segmentation, authenticated encrypted connections, change-controlled firewall policies, one-way flow restrictions where appropriate, and monitoring for unauthorized traffic.

Each row in the separate control-summary workbook identifies whether the control is part of the Moderate baseline or an added OT-specific control. A control outside the Moderate baseline is retained only when its addition has a documented rationale and is supported by the relevant implementation discussion in this SSP. Controls that cannot be justified as necessary for the production-line environment are excluded from the final selected-control set.

The workbook also distinguishes controls inherited from Toyota enterprise services from those tailored or implemented for the production-line system. Enterprise services provide inherited controls such as corporate identity and access management, security operations, vulnerability management, and other common organizational capabilities. Tailored controls identify the system-specific implementation

required for OT devices, programmable logic controllers, human-machine interfaces, supervisory control and data acquisition components, engineering workstations, OT network segments, and OT-DMZ security services.

- Scoping. The team rewrote control wording for OT devices (PLCs, HMIs, SCADA, and engineering workstations). The workbook flags 122 controls as OT overlay controls (Team 5, 2026a).
- Additions. The team added 18 controls beyond the Moderate baseline where the architecture depends on them, including 15 AC-4 information flow enhancements in the Network & Boundary Security area.
- Designation. Each control is marked as Common (provided entirely by Toyota's enterprise services and applied across multiple systems), Hybrid (the enterprise provides part and the line completes the rest, with responsibilities split), or System-specific (implemented only in the RAV4 Hybrid line). Each control is also marked as Inherited if it is provided through shared enterprise services, or Tailored if it is customized for the needs of this system.

13.2 Implementation by control area

The 305 selected controls are discussed in five areas. Sections 13.2.1 through 13.2.4 cover the four areas the team divided among its members, and Section 13.2.5 covers the remaining families, which are almost entirely inherited. Each area opens with a table summarizing its designations; the controls workbook gives the implementation of every individual control (Team 5, 2026a).

13.2.1 Network & Boundary Security (SC family and AC-2 through AC-6(1))

This area comprises 52 controls and enhancements: 27 in the Access Control family (AC-2 through AC-6(1)) and 25 in System and Communications Protection. Table 13.1 summarizes their designations, and the controls workbook describes each control's implementation. The information is based on the team controls workbook (Team 5, 2026a) and the TMMK architecture description (TMMK, 2023). Statements found only in the workbook, such as those about the corporate virtual private network (VPN), authenticated proxies, and SIEM forwarding, are team assumptions about Toyota's enterprise environment.

Area measure	Common	Hybrid	System-specific
All controls in area (52)	4	29	19
Tailored (51)	4	28	19
Inherited (1)	0	1	0

Table 13.1. Designation of controls in the Network & Boundary Security area. Source: Team 5 (2026a).

Key controls in this area are implemented as follows:

- **Account management and access enforcement:** User accounts for OT devices (such as PLCs and HMIs) are provisioned by Toyota's enterprise IAM system. The production line supplements this with OT-specific roles and feeds all account events to the enterprise SIEM for monitoring and auditing.
- **Information flow enforcement:** Allowlist-based ACLs are enforced by the DMZ firewalls at each network zone transition (for example, from enterprise IT to the OT DMZ to the operations

VLANs). All rule changes are reviewed and logged, and one-way flows are used where only one-way transfer is needed, such as read-only inventory data.

- **Boundary protection:** System-specific OT firewalls at the DMZ, authenticated proxies for all external access, and deny-by-default firewall configurations protect the boundary. Vendor and supplier access is tightly controlled and monitored.
- **Transmission, cryptography, and session protection:** Enterprise PKI provides certificates and secure sessions where supported. Encrypted channels (for example, mutual TLS) are configured for device management and data transfers when possible. Where older protocols do not support encryption, network segmentation and firewalls restrict flows.
- **Isolation and system-level protection:** Mechanisms on OT devices separate user and system processes, restrict shared resource access, and prohibit unauthorized mobile code execution. The team validates these setups during system setup and changes.
- **Policy and name resolution:** Corporate IT manages these centrally. The production line ensures all OT devices point to trusted enterprise DNS and policy services, and regularly checks this configuration as part of change management.

Access Control (AC) Family

The Access Control (AC) family governs who can reach OT devices and what actions they can perform. The production line implements AC controls across two layers: Toyota's enterprise IAM provides identity, authentication, and provisioning for all corporate users, while the line adds OT-specific roles (operator, maintenance, and engineering) and enforces them at the device level on PLCs, HMIs, and SCADA systems. This hybrid approach reflects the split responsibility between enterprise IT and plant operations. The 27 AC controls and enhancements selected for this area cover account management (AC-2 and enhancements), access enforcement (AC-3), information flow enforcement (AC-4 and 15 enhancements), separation of duties (AC-5), and least privilege (AC-6 and AC-6(1)). Together, they ensure that only authorized personnel can reach OT systems and that each person has only the access needed for their assigned role.

Account management and access enforcement. These controls decide who can reach OT devices and what they can do. Toyota's enterprise identity and access management (IAM) system handles identity and provisioning, and the line adds OT-specific roles for operators, maintenance staff, and engineers. The hybrid designation reflects that split. Account events feed the enterprise security information and event management (SIEM) system so that changes to PLC, SCADA, and HMI access can be audited.

Information flow enforcement. AC-4 is the control the architecture relies on most. Every zone transition (Enterprise IT to OT DMZ to the Ops, Control, and Floor VLANs) is a controlled flow, allowed only by explicit ACL entries (TMMK, 2023, p. 5). The 15 enhancements go beyond the Moderate baseline. They cover attributes, processing domains, one-way flows, policy filters, change review, and auditing, which together describe how the DMZ firewalls enforce the allowlist and how changes to it are controlled.

System and Communications Protection (SC) Family

The System and Communications Protection (SC) family protects data in transit, at rest, and at the boundaries between network zones. The production line implements SC controls through a combination of inherited enterprise services and system-specific configurations. The line inherits Toyota's enterprise PKI, DNS, and key management, while it configures OT DMZ firewalls, VLAN segmentation, deny-by-default ACLs, and authenticated proxies at every zone boundary. Legacy OT protocols, Modbus, PROFINET, and EtherNet/IP, lack native encryption and authentication, so segmentation and boundary controls provide compensating protection inside the OT network. The 25 SC controls and enhancements

selected for this area cover boundary protection (SC-5, SC-7 and enhancements), transmission confidentiality and integrity (SC-8, SC-10, SC-12, SC-13, SC-17, SC-23), protection of information at rest (SC-28), isolation and system-level protection (SC-2, SC-4, SC-15, SC-18, SC-39), and name resolution services (SC-20, SC-21, SC-22).

Boundary protection. Boundary protection combines inherited corporate firewalls with system-specific OT DMZ firewalls. All external traffic (supplier EDI, vendor maintenance, remote access) enters through the DMZ, where deny-by-default rules and authenticated proxies apply. This limits how far a compromise of corporate IT or a supplier could travel toward the Control and Floor VLANs.

Transmission, cryptography, and session protection. These controls protect data in transit and at rest and keep sessions authentic. Enterprise PKI and key management are inherited, while the line configures cryptography on OT devices where the platform allows it. Many legacy OT protocols (such as Modbus, PROFINET, and EtherNet/IP, listed in the RMF matrix) have no native encryption, so segmentation and the boundary controls above provide that protection inside the OT network.

Isolation and system-level protection. These controls keep functions and processes apart on OT devices: system and user functions, shared resources, execution domains, mobile code, and collaborative devices. They limit what a compromised operator station can do to controller logic.

Policy and name resolution (largely inherited). Toyota Motor North America (TMNA) Corporate IT provides the policy and DNS services. The plant must confirm that OT devices use these enterprise services and that the inheritance is documented.

13.2.2 System Integrity & Flaw Management (SI Family and AC-6(2) through AC-18)

This section covers the System and Information Integrity (SI) family and the Access Control (AC) controls from AC-6(2) through AC-18. Together they hold 38 of the 305 selected controls. Thirty-five are tailored to the production line, and 3 are inherited directly from Toyota's enterprise services (Team 5, 2026a). All but three come from the Moderate baseline; the SP 800-82 OT overlay adds AC-17(9), AC-17(10), and SI-17 (NIST, 2020a, 2023). These controls decide who can change what the line runs and how the line finds out when it has changed, so they carry most of the defense against R-02 and R-03 and part of R-01. Table 13.2 summarizes their designations.

Area measure	Common	Hybrid	System-specific
All controls in area (38)	3	18	17
Tailored (35)	0	18	17
Inherited (3)	3	0	0

Table 13.2. Designation of controls in the System Integrity & Flaw Management area. Source: Team 5 (2026a).

Access Control (AC-6(2) to AC-18): Nineteen tailored controls limit who can change what the line runs and how they reach it. Some of this is in place: TMMK logs computers, monitoring stations, and HMIs off automatically where the function exists (AC-11; TMMK, 2023, p. 14), and keeps wireless on unpublished, encrypted SSIDs preprogrammed onto designated devices, with none in the R&D area (AC-18; TMMK, 2023, pp. 4, 6–7, 9). The rest is planned. OT privileges are split into read and write tiers:

operators view and run the process from HMIs, while only named OT engineers can download PLC logic, override a safety limit, or change a firewall rule, and each of those actions is logged (AC-6(5), AC-6(9), AC-6(10); NIST, 2023, p. 230). HMIs that must stay live through an alarm are not locked out; failed logons there raise an alarm instead, and the badge-controlled area around them protects them (AC-7, AC-11; NIST, 2023, pp. 231–232). All remote access, including vendor support, comes in over the corporate VPN through one managed entry point in the OT DMZ at X1, where OT staff can cut a session quickly and remote commands that change PLC logic must be authenticated (AC-17(3), AC-17(9), AC-17(10); NIST, 2023, p. 233).

System and Information Integrity (SI): Sixteen tailored controls find flaws, malicious code, and unauthorized change; SI-1, SI-8, and SI-8(2) are inherited from Toyota's enterprise services. Several are in place: servers and applications are patched centrally once patches are tested and verified, and intrusion detection at the Edge DMZ watches the OT networks through remote probes (SI-2, SI-4; TMMK, 2023, p. 13). Each SafetySense 2.0 package is entered in a version-controlled registry, verified by the vehicle platform at boot, and hash-checked at Final QA (SI-7, SI-7(1); TMMK, 2023, pp. 5, 10, 13). Planned additions close the gaps: packages signed inside the R&D enclave and verified before installation (SI-7; Team 5, 2026b), OT-protocol monitoring that flags unauthenticated writes to PLCs (SI-4(2)), endpoint protection that alerts rather than quarantines on hosts that run the process (SI-3), and PLC and DCS firmware patched in scheduled maintenance windows, with compensating controls where no patch exists (SI-2; NIST, 2023, pp. 291–292). If control is lost anyway, defined fail-safe states stop robots and halt AGVs (SI-17; NIST, 2023, p. 295).

Planned controls in this area, and any flaw that cannot be patched, are tracked in the Plan of Action and Milestones (POA&M) until they are fully in place (CA-5).

13.2.3 Identity & Access Management (IA Family and AC-18(1) through AC-22)

The Identification and Authentication (IA) family establishes requirements for identifying and authenticating users, devices, systems, and services that access the Toyota Manufacturing OT/ICS environment. The controls apply to authorized personnel, engineering workstations, HMIs, SCADA systems, industrial network devices, PLCs/RTUs, robots, AGVs, and supporting systems, as well as authorized third-party and vendor connections. Authentication mechanisms are implemented based on the capabilities and operational constraints of the OT environment to prevent unauthorized access while maintaining the safety, availability, and reliability of manufacturing operations.

The Access Control (AC) family establishes requirements for controlling and restricting access to the Toyota Manufacturing OT/ICS environment, including PLCs/RTUs, HMIs, SCADA systems, engineering workstations, industrial networks, robots, AGVs, and supporting manufacturing systems.

This area holds 33 of the 305 selected controls, all from the Moderate baseline. Twenty-one, most of the IA family, are inherited from Toyota's enterprise identity services; the 12 tailored controls cover wireless and mobile device access, external systems, information sharing, and authentication on OT devices (AC-18(1) to AC-22, IA-6, IA-7, IA-11). Table 13.3 summarizes their designations, and the controls workbook describes each control (Team 5, 2026a).

Area measure	Common	Hybrid	System-specific
All controls in area (33)	5	24	4

Area measure	Common	Hybrid	System-specific
Tailored (12)	0	8	4
Inherited (21)	5	16	0

Table 13.3. Designation of controls in the Identity & Access Management area. Source: Team 5 (2026a).

In place, the R&D enclave uses unique credentials and two-factor authentication (TMMK, 2023, p. 5), and the OT DMZ hosts a read-only authentication server for the industrial networks (TMMK, 2023, p. 6); OT device authentication (IA-6, IA-7, IA-11) is tailored to limit who can program PLCs, addressing R-03.

13.2.4 Contingency, Recovery & Supply Chain (CM, CP, IR, and SR Families)

This section covers the Configuration Management (CM), Contingency Planning (CP), Incident Response (IR), and Supply Chain Risk Management (SR) control families. Collectively, these families encompass 72 of the 305 selected controls, all drawn from the Moderate baseline (NIST, 2020a, 2020b). Of these, 25 controls are specifically tailored to the local production line, while 47 controls are inherited directly from Toyota's enterprise services (Team 5, 2026a). Designed to mitigate risks R-01, R-02, and R-03, these mechanisms dictate how effectively the line withstands an attack and how quickly it returns to normal operations. Table 13.4 summarizes the specific control designations across this area.

Area measure	Common	Hybrid	System-specific
All controls in area (72)	0	65	7
Tailored (25)	0	18	7
Inherited (47)	0	47	0

Table 13.4. Designation of controls in the Contingency, Recovery & Supply Chain area. Source: Team 5 (2026a).

Configuration Management (CM): Seven tailored controls maintain the line's software, firmware, and configurations in a verified, known state. Any modifications to PLC logic or robotic parameters must undergo formal change control and impact analysis; these updates are validated in a test environment before being deployed during scheduled maintenance windows with an active rollback strategy (CM-3, CM-4; Team 5, 2026b). System modifications are strictly restricted to authorized engineering personnel (CM-5). To minimize the local attack surface, unused ports and services on shop-floor HMIs are disabled, and operator profiles lack software installation privileges (CM-7, CM-11). Containerized software environments are version-controlled within a secure registry hosting an immutable changelog, establishing the official baseline for CM-2 (TMMK, 2023, p. 13), with a cryptographically signed baseline planned for future implementation.

Contingency Planning (CP): Eight tailored controls ensure operational continuity during an infrastructure failure and govern subsequent restoration procedures. The architecture provides a resilient technical foundation: wired control systems utilize a redundant fiber ring network topology (CP-8), critical servers run active-active where supported, with shadow copies and database replication where it is not (CP-7), and server-level backups are written nightly to write-once-read-many (WORM) storage, supplemented by hourly file-level backups (CP-9; TMMK, 2023, p. 13). System recovery involves re-

flashing impacted nodes using clean images pulled directly from the secure software registry (CP-10). A formalized contingency plan, structured staff training, annual testing (CP-2, CP-3, CP-4), and a dedicated alternate storage site (CP-6) are currently planned for deployment on the new production line.

Incident Response (IR): Four tailored controls are implemented to isolate security incidents and minimize shop-floor disruption. On-site engineers can logically quarantine an affected network segment via internal firewalls without triggering a complete plant-wide halt (IR-4; TMMK, 2023, p. 13). The planned response to a failed Final QA hash verification is narrower still: the compromised vehicle is diverted to a physical quarantine area, the associated software delivery stream is frozen, and the vehicle is re-flashed using a known-good master image, aiming for full containment within 10 to 15 minutes (Team 5, 2026b). Local plant incidents are escalated to Toyota's corporate Security Operations Center (SOC) for response support (IR-6, IR-7). OT-specific network anomaly detection (IR-5) is planned.

Supply Chain Risk Management (SR): Six tailored controls secure the physical components and data streams feeding the production environment. Incoming hardware components are scanned into the local inventory tracking system, and samples are routed to Quality Assurance for security and integrity validation before being released to the floor (SR-10, SR-11; TMMK, 2023, p. 5). Inventory data is shared with the AGV and DCS networks on a read-only basis, ensuring a compromised source cannot write commands into active control layers. Supplier contracts and recurring security assessments establish baseline vendor expectations (SR-3, SR-6), while the integration of automated anomaly detection to monitor incoming supplier data feeds is planned (Team 5, 2026b).

13.2.5 Inherited and Assessment Controls (Remaining Families)

The remaining 110 controls fall outside the four areas above. Of these, 101 are inherited from TMNA Corporate IT and plant facilities management: AC-1 and the Awareness and Training (AT), Audit and Accountability (AU), Maintenance (MA), Media Protection (MP), Physical and Environmental Protection (PE), Planning (PL), Personnel Security (PS), Risk Assessment (RA), and System and Services Acquisition (SA) families, along with CA-1. The other nine are tailored Assessment, Authorization, and Monitoring (CA) controls that govern how this plan is assessed and kept current: control assessments (CA-2, CA-2(1)), information exchange and internal system connections (CA-3, CA-9), the POA&M (CA-5), authorization (CA-6), and continuous monitoring (CA-7, CA-7(1), CA-7(4)) (Team 5, 2026a).

13.3 Traceability to Risks

Table 13.5 maps the controls in the Network & Boundary Security area to the five risks in Section 1.1. It also identifies the gaps these controls leave so other control areas can address the residual risk.

Risk	Key controls	How the controls reduce the risk	Limits and where the rest is handled
R-01 JIT supply-chain freeze	SC-7(4), SC-7(5), SC-7(3), SC-7(8), AC-4, AC-4(7), SC-5	Supplier EDI and vendor traffic can enter only through the OT DMZ, which denies by default and restricts sources and destinations. One-way flows and segmentation keep ransomware on a supplier or corporate system from reaching the OT networks, and DoS protection supports availability.	Does not stop a supplier-side outage. Failover to buffered data and vendor risk monitoring belong to the Contingency, Recovery & Supply Chain area.
R-02 Air-gap tampering	SC-7(3), AC-4, AC-4(21), AC-4(15), SC-18, SC-8(1)	The only path from the air-gapped R&D enclave into the OT DMZ is the controlled software delivery crossing. Logical and physical separation of flows, traffic monitoring, restricted mobile code, and encrypted transport reduce what a hostile payload can do after crossing.	Does not verify that the package itself is untampered. Integrity checking (signatures, hashes, registry) belongs to the System Integrity & Flaw Management area.
R-03 Unauthenticated PLC logic manipulation	AC-3, AC-5, AC-6, AC-6(1), SC-2, SC-39, SC-23, AC-4(2), AC-4(21), SC-7	Legacy protocols cannot authenticate commands, so the controls limit who can reach PLCs and what they can change. Access enforcement, least privilege, and limited access to PLC programming restrict who can change logic. Segmentation and separate processing domains confine the network paths to controllers.	Does not add authentication to the protocols. Strong engineer authentication (IA area) and anomaly detection on write commands (SI area) are needed.
R-04 CAN bus exploitation	AC-4(21), SC-7, SC-7(5)	Boundary controls limit the paths from Enterprise IT toward the Floor VLAN and the end-of-line stations.	Limited contribution. A splice at the vehicle harness is a physical attack that network boundaries do not stop. Controls in the System Integrity (QA hash checks) and physical security areas carry this risk.
R-05 Public cloud misconfiguration	AC-2, AC-2(13), AC-6, AC-6(1), SC-28(1)	Account lifecycle, least privilege, and limited access to security functions reduce the chance that one administrator error exposes data.	The workbook scopes these controls to OT devices. Cloud configuration management (CM area) and enterprise IAM carry most of this risk.

Table 13.5. Risk traceability for the Network & Boundary Security area. Risks from Team 5 (2026b).

13.4 Recovery walkthrough

The following sequence illustrates how these tailored controls work together if ransomware compromises a third-party supplier network, as in the 2022 Kojima Industries disruption (NPR, 2022):

1. **Detect:** Intrusion detection at the Edge DMZ, with its remote probes in the OT networks, flags and logs suspicious activity (TMMK, 2023, p. 13).
2. **Contain:** On-site engineers immediately isolate the compromised network zone using internal firewalls, stopping lateral malware propagation to the automated field control layers (IR-4).
3. **Report:** The ISSO escalates the event to the centralized corporate Security Operations Center for joint containment coordination (IR-6).
4. **Sustain operations:** Active-active server clusters and the underlying redundant fiber ring architecture maintain normal execution across all unaffected production line cells (CP-7, CP-8).
5. **Restore:** Compromised systems are wiped and rebuilt from the nightly WORM backups, which ransomware cannot modify or encrypt, and brought up to date from the hourly file-level backups (CP-9).
6. **Verify:** Disrupted nodes are re-flashed using verified registry images, and software hashes are validated against the hashes recorded in the registry before authorizing a physical line restart (CP-10).
7. **Improve:** Post-incident findings and forensic timelines are analyzed to update the master contingency plan and tune network monitoring rule sets (CP-2, CP-4).

All controls described throughout this section as planned will be formally tracked within the system's Plan of Action and Milestones (POA&M) until they achieve full implementation status.

14. Summary

This System Security Plan (SSP) sets out a structured, risk-based approach to protecting the TMMK RAV4 Hybrid Production Line, and its implementation will strengthen the security posture of the line's operational technology (OT) environment. The SSP was developed using the Risk Management Framework (RMF) described in NIST SP 800-37 (NIST, 2018), with security controls selected and tailored using NIST SP 800-53 Rev. 5 (NIST, 2020b) and NIST SP 800-53B (NIST, 2020a). NIST SP 800-82 Rev. 3 (NIST, 2023) was also considered to address the unique security and operational requirements of the OT environment. Based on the system characteristics and risk assessment completed for this assignment, the TMMK system was categorized as a Moderate-impact system.

The selected controls are intended to address the risks identified during the initial risk assessment, including risks to manufacturing availability and supply-chain continuity (R-01), OT system and control-logic integrity (R-02 and R-03), vehicle CAN bus exposure (R-04), and cloud data confidentiality (R-05). Implementation of the selected controls is expected to reduce the likelihood and/or impact of these risks by strengthening access control, supply-chain and external-system protections, system and communications protection, configuration and change management, information integrity, incident response, and security assessment and monitoring. These controls will help protect the OT environment from unauthorized access, unauthorized communications, system compromise, malicious code, and unauthorized configuration or control-logic changes while maintaining appropriate separation between Enterprise IT, OT supervisory systems, control systems, and manufacturing equipment.

Five processes keep the line secure day to day. Patches are tested before deployment, and PLC and DCS firmware is updated in scheduled maintenance windows, with compensating controls where no patch exists (SI-2). Intrusion detection at the Edge DMZ, with probes in the OT networks, watches for unauthorized traffic, and planned OT-protocol monitoring will flag unauthenticated writes to PLCs (SI-4). Every change to PLC logic, firewall rules, or software passes through formal change control and is tested before release (CM-3, CM-4). Nightly WORM backups, which ransomware cannot alter, allow compromised systems to be rebuilt from a known-good state (CP-9, CP-10). When an incident occurs, the affected zone is isolated at the internal firewalls while the rest of the line keeps running (IR-4). Together these processes shorten the time an attacker can act unnoticed and keep a single compromise from stopping the whole line.

The effectiveness of the implemented controls will be evaluated through security control assessments, continuous monitoring, and periodic risk reassessments. The results of these activities will be used to determine residual risk and identify additional safeguards or corrective actions where necessary. Risks that originate outside the TMMK OT authorization boundary, such as the vehicle CAN bus risk (R-04) and the cloud related confidentiality risk (R-05), are documented for contextual awareness and may require mitigation through enterprise-level or external system owners and controls.

Because this SSP was developed as a practical course exercise with limited access to TMMK's actual environment, reasonable assumptions were made regarding existing enterprise-level security capabilities, including identity and access management, physical security, and administrative safeguards. These assumptions should be validated against the actual TMMK environment during subsequent assessment and authorization activities.

This SSP is intended to be a living document and will be reviewed and updated as the TMMK OT environment, threats, vulnerabilities, technologies, operational processes, and security requirements change. Continuous monitoring, security control assessments, risk reassessments, and changes to the system or operating environment will be used to identify required updates and ensure that the SSP remains accurate and representative of the system's security posture. Overall, implementation and continuous maintenance of the SSP will establish a consistent and documented approach for managing cybersecurity risk while supporting the safe, reliable, and continuous operation of Toyota's manufacturing processes.

15. References

CVE Details. (2023). *Vulnerability details: CVE-2023-29389*. https://www.cvedetails.com/cve/CVE-2023-29389/

Cyber Incident Reporting for Critical Infrastructure Act of 2022, 6 U.S.C. § 681 et seq. (2022).

Cybersecurity and Infrastructure Security Agency. (n.d.). *Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA)*. Retrieved October 4, 2026, from https://www.cisa.gov/topics/cyber-threats-and-advisories/information-sharing/cyber-incident-reporting-critical-infrastructure-act-2022-circia

Defend Trade Secrets Act of 2016, 18 U.S.C. § 1836 (2016).

Federal Motor Vehicle Safety Standards, 49 C.F.R. Part 571 (2026). https://www.ecfr.gov/current/title-49/subtitle-B/chapter-V/part-571

Goodin, D. (2023, April 7). *There's a new form of keyless car theft that works in under 2 minutes*. Ars Technica. https://arstechnica.com/information-technology/2023/04/crooks-are-stealing-cars-using-previously-unknown-keyless-can-injection-attacks/

International Automotive Task Force. (2016). *IATF 16949:2016* (1st ed.). https://www.iatfglobaloversight.org/iatf-169492016/about/

International Electrotechnical Commission. (2020). *Security for industrial automation and control systems — Part 3-2: Security risk assessment for system design* (IEC 62443-3-2:2020). https://webstore.iec.ch/en/publication/30727

International Organization for Standardization. (2018). *Road vehicles — Functional safety — Part 6: Product development at the software level* (ISO Standard No. 26262-6:2018). https://www.iso.org/obp/ui/#iso:std:iso:26262:-6:ed-2:v1:en

International Organization for Standardization & SAE International. (2021). *Road vehicles — Cybersecurity engineering* (ISO/SAE Standard No. 21434:2021). https://www.iso.org/standard/70918.html

Kentucky Uniform Trade Secrets Act, Ky. Rev. Stat. §§ 365.880–365.900 (2025). https://law.justia.com/codes/kentucky/chapter-365/

National Highway Traffic Safety Administration. (2022). *Cybersecurity best practices for the safety of modern vehicles*. U.S. Department of Transportation. https://www.nhtsa.gov/sites/nhtsa.gov/files/2022-09/cybersecurity-best-practices-safety-modern-vehicles-2022-tag.pdf

National Institute of Standards and Technology. (2004). *Standards for security categorization of federal information and information systems* (Federal Information Processing Standards Publication 199). U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf

National Institute of Standards and Technology. (2006). *Guide for developing security plans for federal information systems* (NIST Special Publication 800-18, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-18r1

National Institute of Standards and Technology. (2008a). *Guide for mapping types of information and information systems to security categories* (NIST Special Publication 800-60, Volume I, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-60v1r1

National Institute of Standards and Technology. (2008b). *Volume II: Appendices to guide for mapping types of information and information systems to security categories* (NIST Special Publication 800-60, Volume II, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-60v2r1

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2018). *Risk management framework for information systems and organizations: A system life cycle approach for security and privacy* (NIST Special Publication 800-37, Revision 2). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-37r2

National Institute of Standards and Technology. (2020a). *Control baselines for information systems and organizations* (NIST Special Publication 800-53B). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53B

National Institute of Standards and Technology. (2020b). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2021). *Managing the security of information exchanges* (NIST Special Publication 800-47, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-47r1

National Institute of Standards and Technology. (2022). *Cybersecurity supply chain risk management practices for systems and organizations* (NIST Special Publication 800-161, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-161r1

National Institute of Standards and Technology. (2023). *Guide to operational technology (OT) security* (NIST Special Publication 800-82, Revision 3). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-82r3

National Traffic and Motor Vehicle Safety Act, 49 U.S.C. §§ 30118–30120. https://www.law.cornell.edu/uscode/text/49/subtitle-VI/part-A/chapter-301

NPR. (2022, February 28). *Toyota stops production in Japan after a cyberattack hits one of its suppliers*. https://www.npr.org/2022/02/28/1083550554/toyota-stops-production-in-japan-after-a-cyberattack-hits-one-of-its-suppliers

Powell, O. (2023, May 19). *IOTW: Location data of two million customers exposed in Toyota data breach*. Cyber Security Hub. https://www.cshub.com/attacks/news/location-data-of-2-million-customers-exposed-in-toyota-data-breach

Team 5. (2026a). *SSP controls selection workbook* [Unpublished course document, Microsoft Excel file]. SIE 573, University of Arizona.

Team 5. (2026b). *Risk management assessment: Toyota Motor Manufacturing Kentucky (TMMK) RAV4 Hybrid* [Unpublished course assignment]. SIE 573, University of Arizona.

Toyota Motor Manufacturing Kentucky. (2023). *Architectural description for Toyota Motor Manufacturing* [Course project document]. SIE 573, University of Arizona.

16. Appendix A. Acronyms and Terms

This appendix spells out every acronym used in this System Security Plan, lists the NIST SP 800-53 control family abbreviations, defines terms that carry a specific meaning in this document, and lists the subsystem identifiers.

A.1 Acronyms

Table A.1. Acronyms

Acronym	Meaning
ACL	Access control list
AGV	Automated guided vehicle
AO	Authorizing Official
ASPICE	Automotive Software Process Improvement and Capability Determination
ATO	Authorization to Operate
C/I/A	Confidentiality, integrity, availability
CAN	Controller Area Network
C.F.R.	Code of Federal Regulations
CISA	Cybersecurity and Infrastructure Security Agency
CISO	Chief Information Security Officer
CVE	Common Vulnerabilities and Exposures
DCS	Distributed control system
DMZ	Demilitarized zone
DNS	Domain Name System
DNSSEC	Domain Name System Security Extensions
DoS	Denial of service
EDI	Electronic data interchange
ERP	Enterprise resource planning
EtherNet/IP	Ethernet Industrial Protocol
FIPS	Federal Information Processing Standards
HMI	Human-machine interface
HR	Human resources
HVAC	Heating, ventilation, and air conditioning
IAM	Identity and access management
IATF	International Automotive Task Force
ICS	Industrial control system

Acronym	Meaning
ID	Identifier
IDS	Intrusion detection system
IEC	International Electrotechnical Commission
IP	Internet Protocol
IPS	Intrusion prevention system
IPsec	Internet Protocol Security
ISA	Interconnection security agreement
ISO	International Organization for Standardization
ISSO	Information System Security Officer
IT	Information technology
JIT	Just-in-Time
KRS	Kentucky Revised Statutes
MAC	Media access control
MES	Manufacturing execution system
MOU	Memorandum of understanding
NHTSA	National Highway Traffic Safety Administration
NIST	National Institute of Standards and Technology
Ops	Operations
OT	Operational technology
OTA	Over-the-air
PKI	Public key infrastructure
PLC	Programmable logic controller
POA&M	Plan of Action and Milestones
POC	Point of contact
PROFINET	Process Field Network
QA	Quality assurance
R&D	Research and development
RBAC	Role-based access control
RFID	Radio-frequency identification
RMF	Risk Management Framework
RTU	Remote terminal unit
SAE	SAE International (formerly the Society of Automotive Engineers)

Acronym	Meaning
SAR	Security Assessment Report
SCADA	Supervisory control and data acquisition
SDLC	System development life cycle
SIEM	Security information and event management
SOC	Security Operations Center
SP	Special Publication (NIST)
SSID	Service set identifier
SSP	System Security Plan
TLS	Transport Layer Security
TMMK	Toyota Motor Manufacturing Kentucky
TMNA	Toyota Motor North America
TPM	Trusted Platform Module
U.S.C.	United States Code
VIN	Vehicle identification number
VLAN	Virtual local area network
VPN	Virtual private network
WORM	Write once, read many

A.2 Control Family Abbreviations

Table A.2. NIST SP 800-53 Rev. 5 control families

Family	Name
AC	Access Control
AT	Awareness and Training
AU	Audit and Accountability
CA	Assessment, Authorization, and Monitoring
CM	Configuration Management
CP	Contingency Planning
IA	Identification and Authentication
IR	Incident Response
MA	Maintenance
MP	Media Protection
PE	Physical and Environmental Protection
PL	Planning

Family	Name
PS	Personnel Security
RA	Risk Assessment
SA	System and Services Acquisition
SC	System and Communications Protection
SI	System and Information Integrity
SR	Supply Chain Risk Management

A.3 Terms and Definitions

Table A.3. Terms and definitions

Term	Meaning in this SSP
Air gap	Physical isolation with no network connection, as used for the R&D enclave.
Allowlist	A list of explicitly permitted traffic; everything else is denied. The architecture document calls this a “whitelist.”
Authorization boundary	The components the Authorizing Official authorizes to operate as one system, defined in Section 1.
Common control	A control provided by an organization-wide source, here TMNA Corporate IT, that the system uses without implementing it.
Hybrid control	A control implemented partly by the common control provider and partly by the system.
Inherited / Tailored	Inherited: provided through Toyota’s enterprise services. Tailored: customized for this system.
High-water mark	The rule that a system’s impact level for each objective equals the highest level of any information type or subsystem within it.
Planned / In place	In place: described in the architecture document. Planned: proposed in the RMF assessment and tracked in the POA&M.
Purdue model	A reference architecture that divides industrial networks into layers, from enterprise systems down to field devices.
System / Subsystem	The system is the TMMK RAV4 Hybrid Production Line. Subsystems are its components listed in Section 2 and Table A.4, each with its own ID.

A.4 Subsystem Identifiers

Table A.4. Subsystem identifiers

ID	Subsystem
RAV4-PL-EIT	Enterprise IT Interface (outside the authorization boundary)
RAV4-PL-DMZ	OT DMZ
RAV4-PL-OPS	Ops VLAN

ID	Subsystem
RAV4-PL-CTL	Control VLAN
RAV4-PL-FLR	Floor VLAN
RAV4-PL-AGV	AGV System
RAV4-PL-ENV	Environmental SCADA
RAV4-PL-DCS	DCS
RAV4-PL-SWD	Software Delivery and R&D
RAV4-PL-HSC	Hardware Supply Chain
RAV4-PL-FQA	Final QA and Vehicle Database

Maximo SCADA Maintenance Control has no subsystem ID. It is treated as an external enterprise service outside the authorization boundary (Section 11.2).